Secure Network Infrastructure for a Medical Appointment Platform

A fully virtualized defense-in-depth lab (proof of concept)

JusDeKiwi

October 2026

Lab proof of concept. All data is fictitious, addresses use documentation and private ranges, and no real secret is included. The lab domain is mediconnect.lab.

Contents

1 Context and objectives **2**
1.1 Security objectives 2
1.2 Structuring technical choices 2

2 Global architecture **3**

3 Addressing plan **4**

4 Security zones and trust levels **6**

5 VPN **7**
5.1 Site interconnection: IPsec IKEv2 7
5.2 Remote access: OpenVPN 9

6 Authentication and PKI **10**
6.1 Internal certificate authority 10
6.2 LDAP directory and authentication factors 11

7 Filtering policy and identity-based rules **13**

8 Application control **15**

9 DMZ protection and portal exposure **17**

10 Secure administration **19**

11 Logging and monitoring **21**

12 Test campaign **24**
12.1 Patients, doctors and exposure (T01 to T05) 24
12.2 Interconnection and isolation of site 2 (T07, T08) 25
12.3 Identity-based remote access (T09 to T14) 26
12.4 Administration separation (T16) 26
12.5 Demonstration and refused flows (T06, T17) 27
12.6 Attack detection and correlation (T15, T18, T19, T20) 28

13 Limitations **28**

14 Conclusion **28**

A Virtual machines inventory **30**

B Key configurations **30**

B.1 nginx: public portal and doctor area 30

B.2 Local nftables firewall (servers and DMZ) 31

B.3 SSH server hardening 31

B.4 Wazuh: decoder and custom rules 31

B.5 Test scripts 32

1 Context and objectives

Nowadays, protecting health data has become a major concern for our society. Indeed, with the rise of online medical services and stricter regulations, any platform that handles appointments or patient records has to take its responsibilities, whatever its size. This project secures the network infrastructure of a medical appointment platform.

The platform is spread across two sites, with several populations that do not share the same needs, nor the same level of trust: patients who browse the public portal, doctors who reach a professional area, remote employees split into five business groups, a sales team who presents the product, and the administrators who operate everything. That is why security cannot come down to a single firewall. It is intimately linked to the architecture, to the identity of each user, and to the logging of what happens.

This work is a proof of concept, fully virtualized under VMware Workstation. The guiding principle stayed constant: for each requirement, keep the simplest control that really satisfies it. The goal is not to rebuild a full production system, but to show that the expected mechanisms are in place and that they work.

1.1 Security objectives

The project answers the following objectives.

- Interconnect the two sites in a secure way.
- Give remote employees an access limited to their profile.
- Give the sales team an access to the CRM and to a demo zone, never to production.
- Expose the portal to patients over HTTPS only, without any access to the internal network.
- Authenticate doctors with a strong mechanism (MFA), without opening the internal network to them.
- Separate production from demonstration.
- Control the applications that are used.
- Apply a filtering policy that depends on the identity.
- Administer the infrastructure through a channel separated from the user traffic.
- Log the security events in a central place.

1.2 Structuring technical choices

The main choices are summarized in table 1. Each one was made for its simplicity and because it answers a precise requirement.

Each zone is a fully isolated VMware segment, connected to the others only through the firewall. Consequently, isolation is obtained by construction, which is simpler and leaves no possible communication outside the firewall. However this choice is specific to the lab: on a physical network, one would use VLANs. This point comes back in the limitations (section 13).

Need	Chosen solution
Hypervisor	VMware Workstation
Segmentation	One isolated virtual network per zone, no VLAN (the firewall has one interface per zone)
Firewall	OPNsense, one per site (IPsec, OpenVPN, Suricata, LDAP authentication, certificate authority)
Identity	OpenLDAP, the groups are the business profiles
SIEM	Wazuh, collection and correlation of the logs
Site-to-site VPN	IPsec IKEv2 with a strong pre-shared key
Remote access VPN	OpenVPN (client certificate and LDAP credentials)
Doctor MFA	Client certificate and password (possession and knowledge)
PKI	Internal authority managed by OPNsense
Applications	Simulated by nginx (static pages, fictitious data)
Application control	Suricata in IPS mode with the OPNsense-App-detect ruleset

Table 1. Technical choices and justification

2 Global architecture

The infrastructure is made of twelve virtual machines, spread across the headquarters, a branch site and a simulated Internet. The headquarters hosts the main firewall, the servers, the DMZ, the demo zone and the management zone. The branch site only holds a firewall and a user workstation. Figure 1 shows the whole.

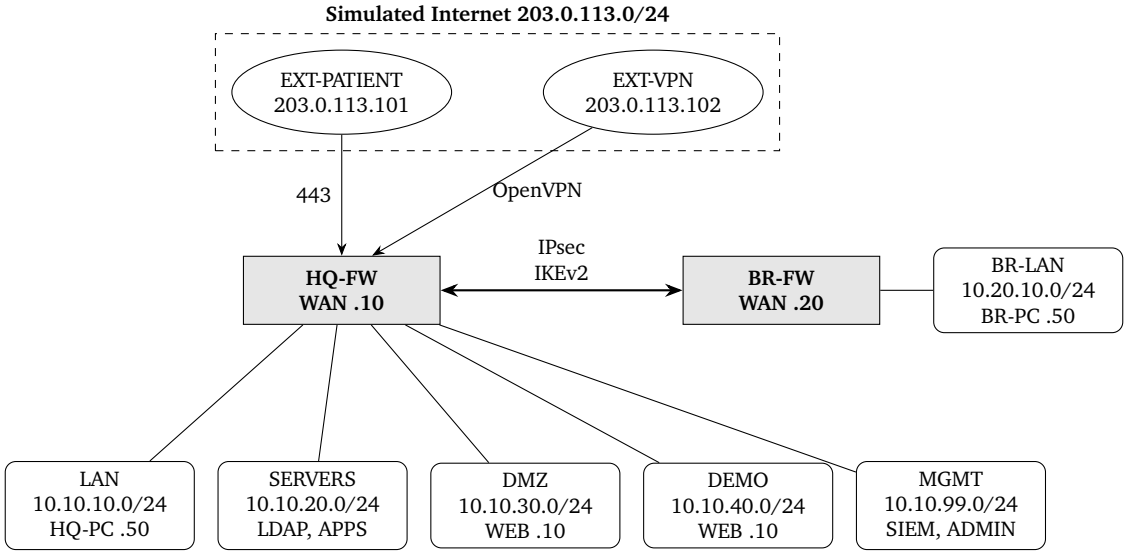


Figure 1. General architecture: two sites linked by IPsec, isolated zones at headquarters

Each zone of the headquarters is a distinct VMware segment. The HQ-FW firewall has one network card per zone and carries the `.1` address on each. Consequently, any communication between two zones has to go through it, where it is filtered and logged. The branch site is linked to the headquarters by an IPsec tunnel, and both its administration traffic and its logs go through that tunnel.

Figure 2 shows the virtual machines running in VMware, and figure 3 the network segments created to isolate the zones.

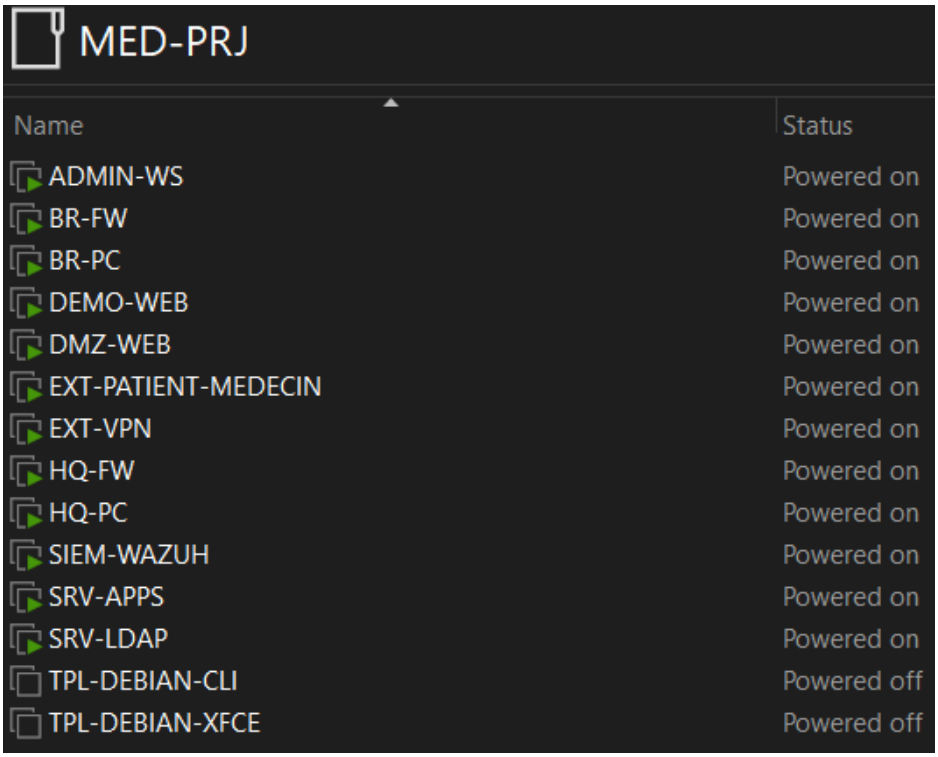


Figure 2. The project virtual machines running

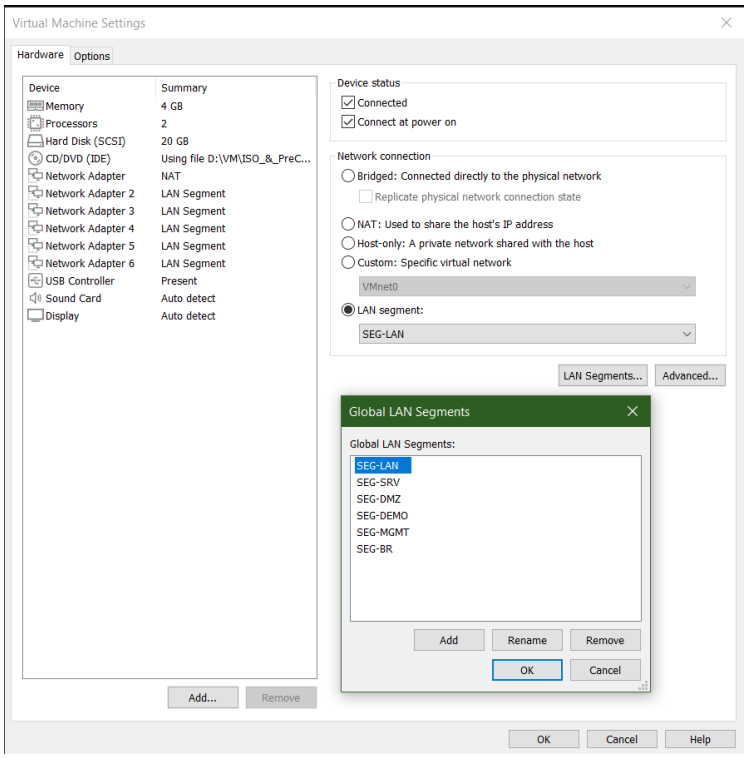


Figure 3. VMware network segments (one isolated segment per zone, no VLAN)

3 Addressing plan

The addressing is fully static. There is no DHCP, which keeps the whole reproducible and makes the logs easier to read. Table 2 gives the complete plan.

Zone	Network	Gateway	Main hosts
Simulated Internet	203.0.113.0/24	NAT .2	HQ-FW .10, BR-FW .20, EXT-PATIENT .101, EXT-VPN .102
HQ LAN	10.10.10.0/24	.1	HQ-PC .50
Servers	10.10.20.0/24	.1	SRV-LDAP .10, SRV-APPS .20 (alias .21 to .25)
DMZ	10.10.30.0/24	.1	DMZ-WEB .10
Demonstration	10.10.40.0/24	.1	DEMO-WEB .10
Management	10.10.99.0/24	.1	SIEM-WAZUH .10, ADMIN-WS .50
Branch LAN	10.20.10.0/24	.1	BR-PC .50
OpenVPN tunnel	10.8.0.0/24		one /28 per group

Table 2. Addressing plan

The business resources are simulated on SRV-APPS. Each resource has its own IP address and its own nginx instance, which allows precise filtering rules, one resource per allowed group (table 3).

Address	Resource	Allowed group
10.10.20.21	CRM	sales
10.10.20.22	Support apps	support
10.10.20.23	Accounting server	accounting
10.10.20.24	Office resources	employees
10.10.20.25	Technical resources (web + SSH)	IT

Table 3. Business resources and allowed group

Each remote group gets a range of the 10.8.0.0/24 network, and each user a fixed address inside that range (table 4). That fixed address is the key of the identity policy: it lets the firewall recognize the user by his sole address and apply the right rules.

LDAP group	Tunnel range	Test user (fixed IP)
grp-support	10.8.0.16/28	u.support (10.8.0.17)
grp-compta	10.8.0.32/28	u.compta (10.8.0.33)
grp-employes	10.8.0.48/28	u.employe (10.8.0.49)
grp-it	10.8.0.64/28	u.it (10.8.0.65)
grp-admins	10.8.0.80/28	u.admin (10.8.0.81)
grp-commerciaux	10.8.0.96/28	u.commercial (10.8.0.97)

Table 4. OpenVPN ranges and fixed address per user

The interfaces configured on both firewalls confirm this plan. Figure 4 shows the six interfaces of HQ-FW and figure 5 the two interfaces of BR-FW.

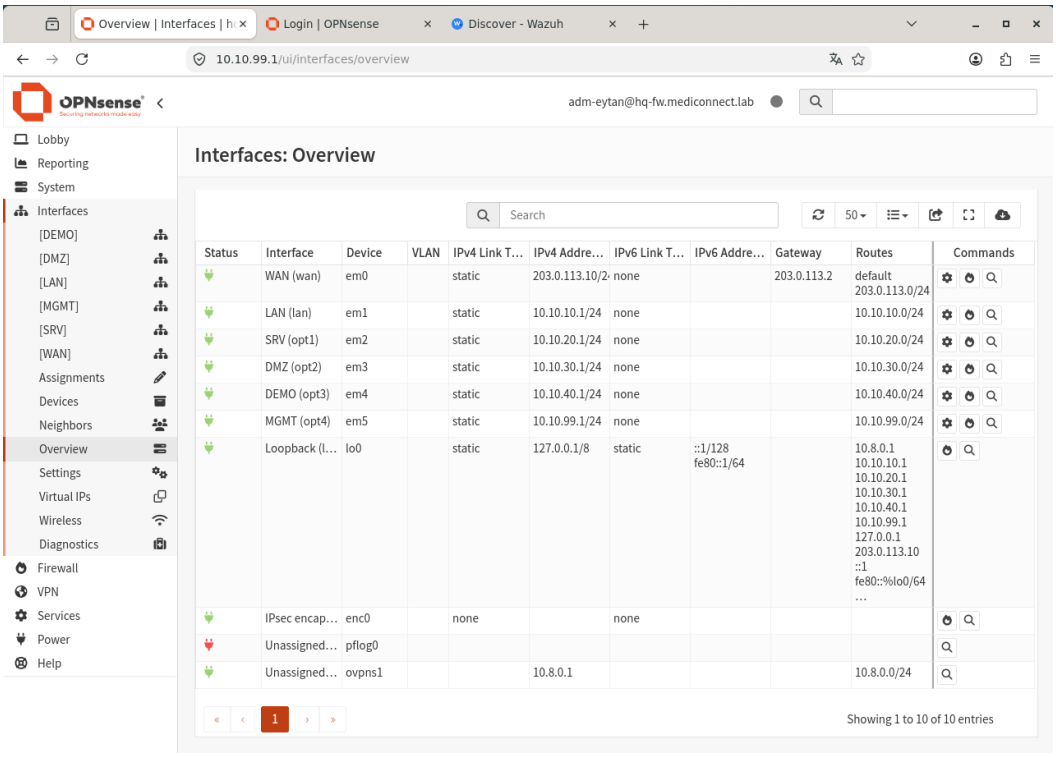


Figure 4. HQ-FW interfaces: WAN, LAN, SRV, DMZ, DEMO, MGMT

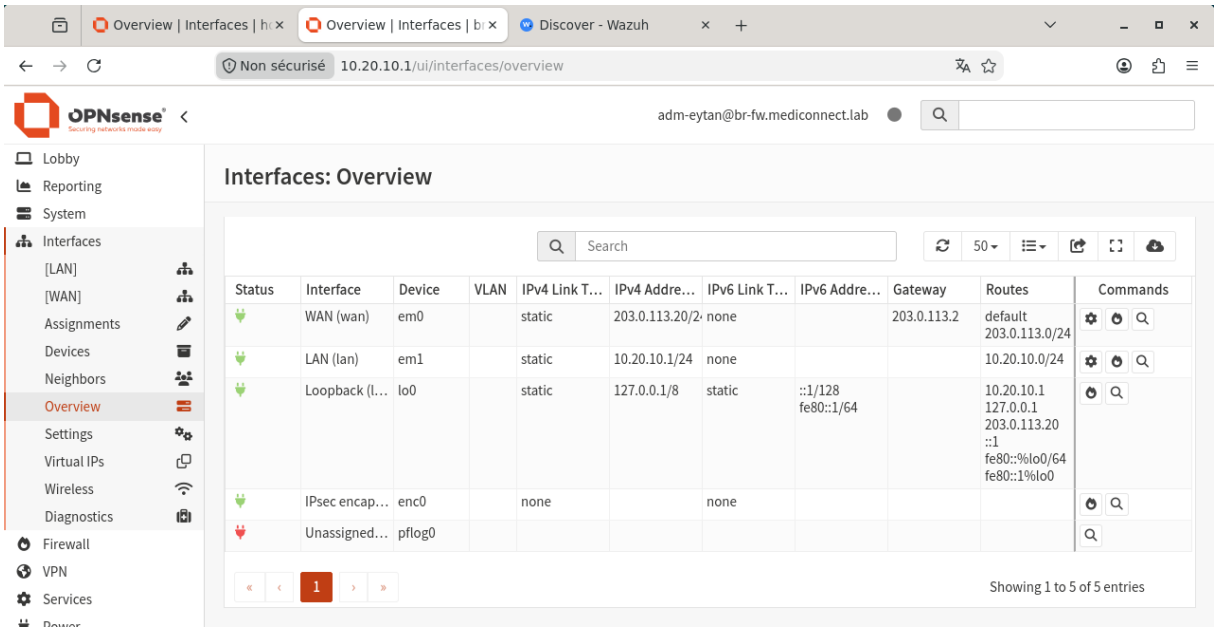


Figure 5. BR-FW interfaces: WAN and LAN of the branch site

4 Security zones and trust levels

Each zone gets a trust level, from the least to the most critical. This ranking guides the whole filtering policy: a flow that climbs toward a more sensitive level has to be justified by an explicit exception, and everything else is denied. Table 5 sums up these levels.

The default policy of each interface is deny (*deny any*), with logging. Only what is needed is opened afterward. Consequently, a missing rule never creates a hole, it becomes a block that is

Zone	Level	General rule
Internet	0, untrusted	nothing inbound except 443 toward the DMZ and the VPN
DMZ	1, exposed	cannot initiate anything toward the inside, except its logs to the SIEM
Demonstration	1, isolated	no link with production, nor with real data
Branch LAN	3, remote internal	limited access to business resources through the tunnel
HQ LAN	3, internal	Internet egress and targeted resources, no administration
Servers	4, sensitive	reachable only from authorized flows
Management	5, critical	reachable only by the administrators

Table 5. Zones and trust levels

visible in the logs, and not an unintended allow.

5 VPN

Two VPNs answer two different needs. The first links the two sites in a permanent way. The second gives a remote access to nomad users, with rights that depend on their group.

5.1 Site interconnection: IPsec IKEv2

The tunnel between HQ-FW and BR-FW is an IPsec IKEv2. Phase 1 uses AES-256, SHA-256 and the Diffie-Hellman MODP-2048 group, with an authentication by a strong pre-shared key. Phase 2 encrypts the traffic between the headquarters network (10.10.0.0/16) and the branch one (10.20.10.0/24).

Figure 6 shows the connection defined on HQ-FW, and figure 7 its state: phase 1 is established and phase 2 is installed, in both directions.

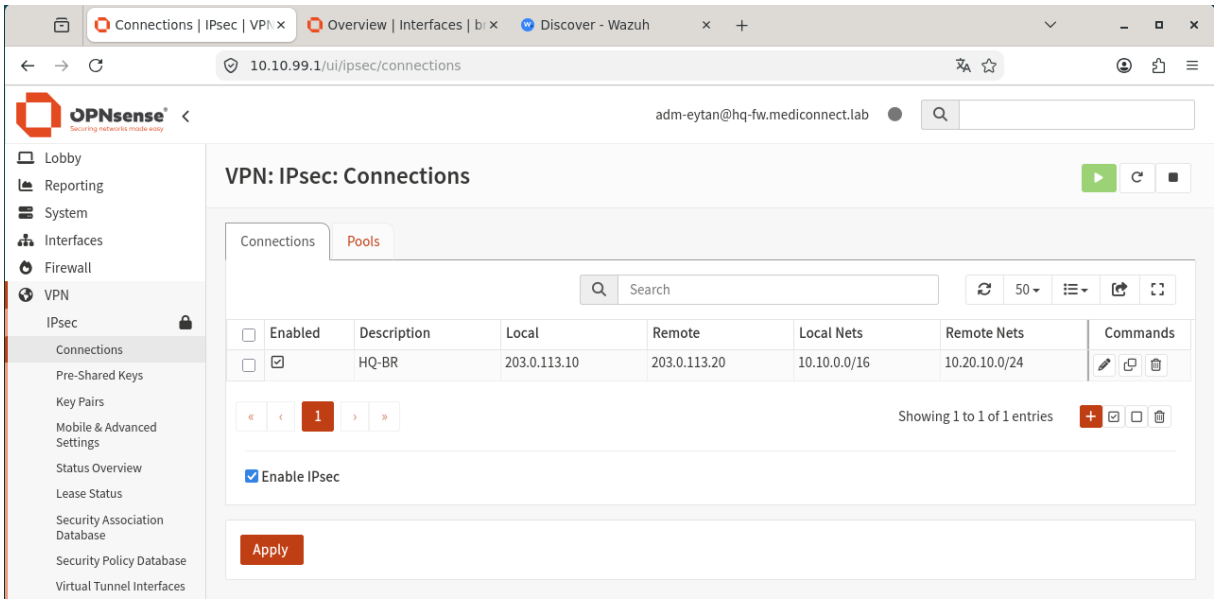


Figure 6. IPsec: HQ-BR connection defined on HQ-FW

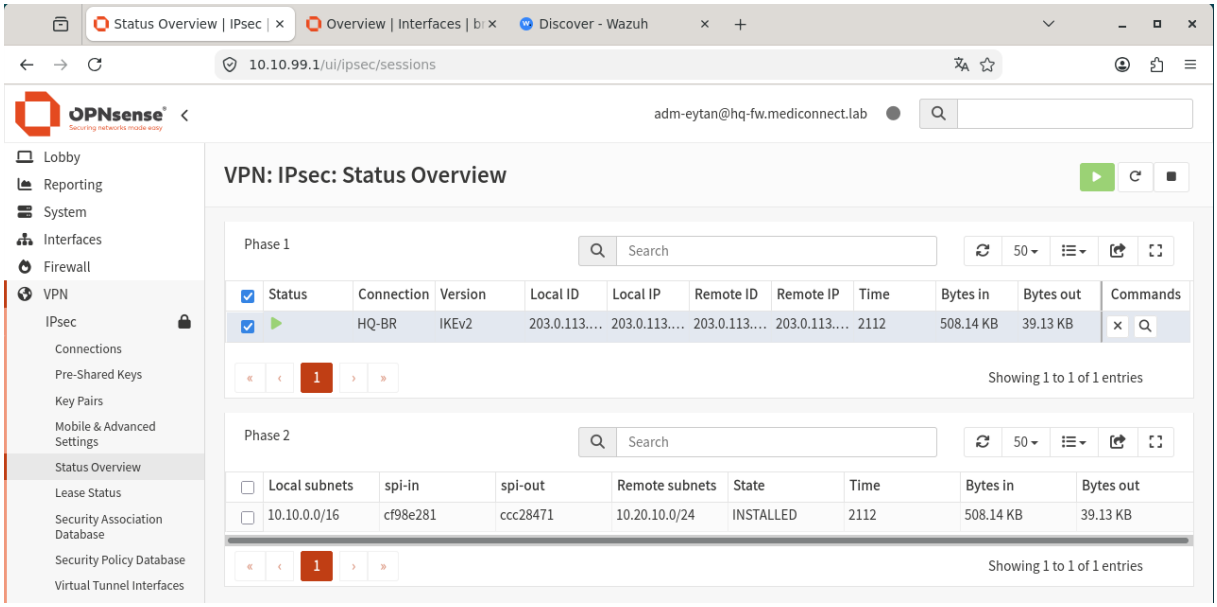


Figure 7. IPsec: phase 1 established and phase 2 installed (HQ-FW view)

To check that the traffic is really encrypted and not in clear text, a `tcpdump` capture on the WAN interface only shows ESP packets between the two firewalls (figure 8). Indeed the ESP protocol carries the encrypted payload: an observer on the "Internet" link does not see the content.

```
root@hq-fw:~ # tcpdump -ni em0 -c 6 esp
tcpdump: verbose output suppressed, use -v[v]... for full protocol decode
listening on em0, link-type EN10MB (Ethernet), snapshot length 262144 bytes
17:41:04.575376 IP 203.0.113.20 > 203.0.113.10: ESP(spi=0xc62cb32a,seq=0x1), len
gth 104
17:41:05.083311 IP 203.0.113.20 > 203.0.113.10: ESP(spi=0xc62cb32a,seq=0x2), len
gth 104
17:41:05.086245 IP 203.0.113.10 > 203.0.113.20: ESP(spi=0xcd7f6f42,seq=0x1), len
gth 104
17:41:05.086322 IP 203.0.113.10 > 203.0.113.20: ESP(spi=0xcd7f6f42,seq=0x1), len
gth 104
17:41:06.070218 IP 203.0.113.20 > 203.0.113.10: ESP(spi=0xc62cb32a,seq=0x3), len
gth 104
17:41:06.070485 IP 203.0.113.10 > 203.0.113.20: ESP(spi=0xcd7f6f42,seq=0x2), len
gth 104
6 packets captured
250 packets received by filter
0 packets dropped by kernel
root@hq-fw:~ #
```

Figure 8. Traffic between the two sites: only ESP (encrypted)

5.2 Remote access: OpenVPN

The remote access relies on OpenVPN over UDP 1194. The authentication combines two factors: a client certificate signed by the internal authority, and the LDAP credentials of the user. The chosen mode binds the username to the certificate name (*username as common name*), which guarantees that a user cannot present himself with the certificate of another.

The `tls-crypt` key adds a further protection. It encrypts and authenticates the negotiation from the very first packet, with a shared secret. That is why a scanner that sends a packet on port 1194 gets no answer: the server is invisible as long as one does not hold this key. The instance configuration (figure 9) shows the tunnel network, the server certificate, the requirement of the client certificate and the LDAP authentication.

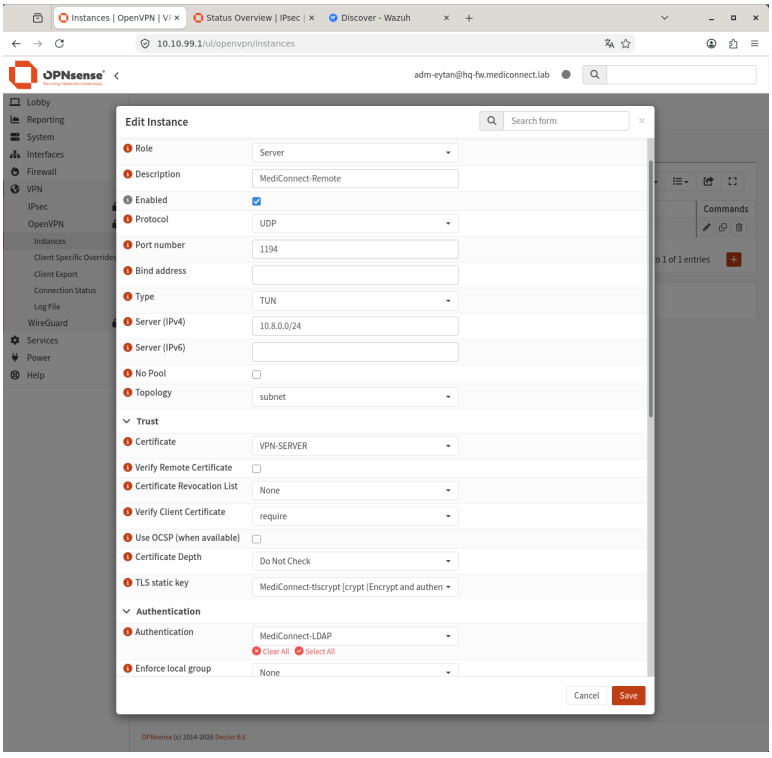


Figure 9. OpenVPN instance: tls-crypt, client certificate required, LDAP authentication

The fixed address per user is assigned by the *Client Specific Overrides* (figure 10). Each account always gets the same address inside the range of its group. These addresses are then grouped into OPNsense aliases, which allows readable rules such as "the support group goes to the support application".

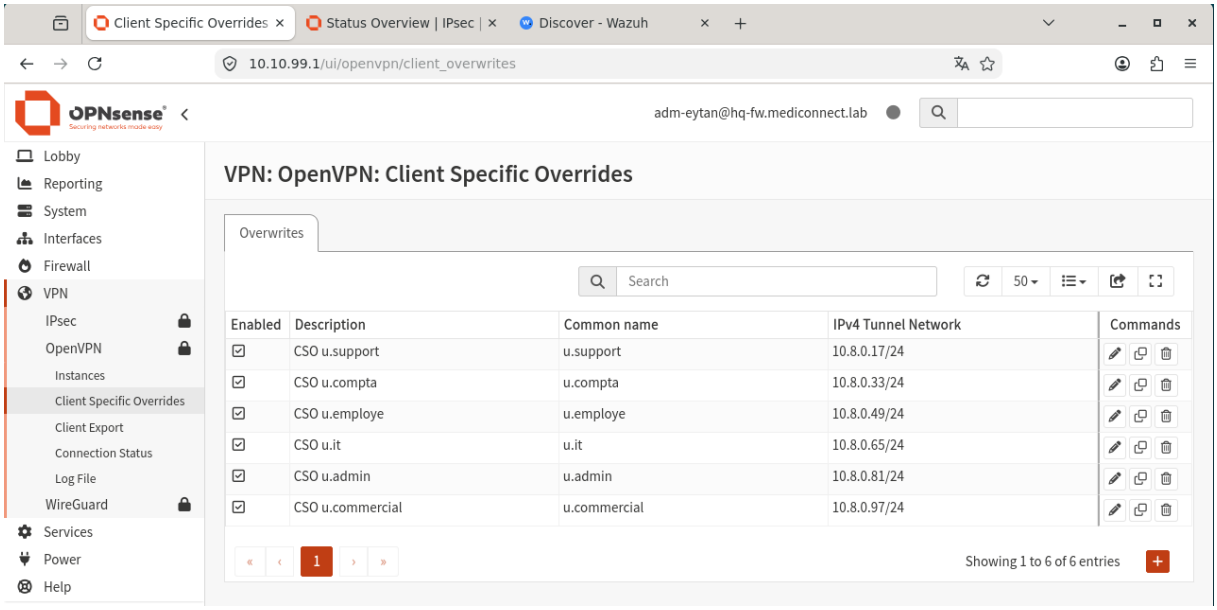


Figure 10. Fixed address per user (Client Specific Overrides)

6 Authentication and PKI

6.1 Internal certificate authority

A single certificate authority, managed by OPNsense (figure 11), issues every certificate of the lab: the server certificate of the portal and the professional area, the OpenVPN server certificate, the one of the firewall GUI, and one client certificate per VPN user and per test doctor (figure 12). This authority is imported into the client hosts so they recognize the server certificates as valid.

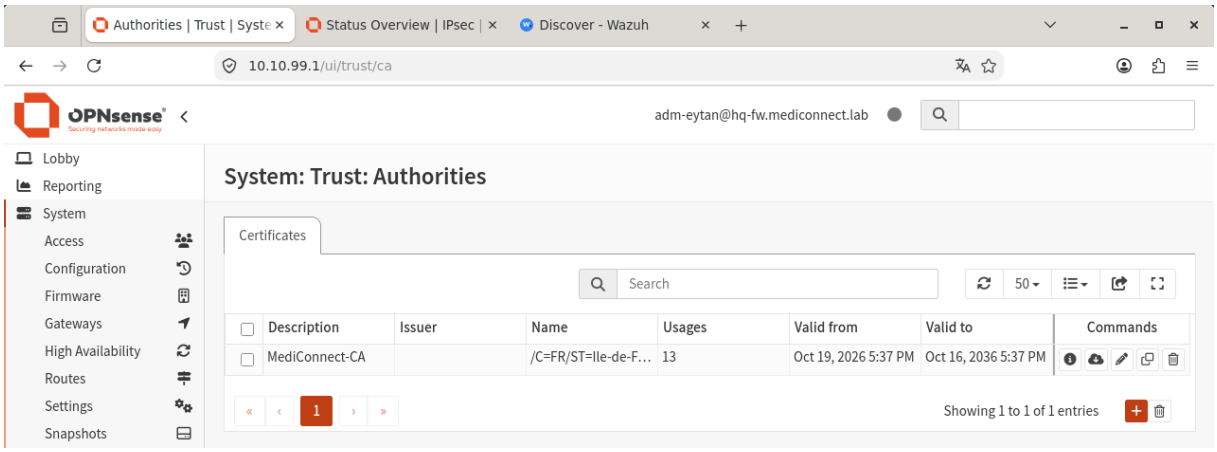


Figure 11. Internal certificate authority

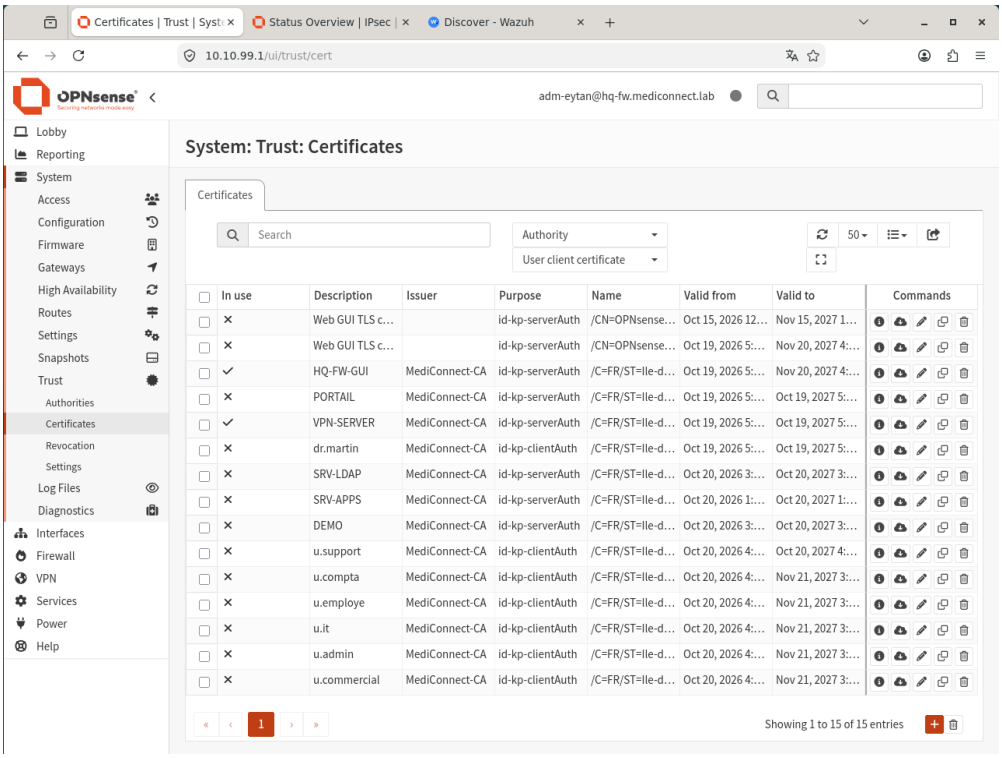


Figure 12. Certificates issued by the authority (servers and clients)

6.2 LDAP directory and authentication factors

The OpenLDAP directory holds six groups that match the business profiles exactly, with one test user per group. The firewall queries this directory to authenticate the VPN connections (figure 13). A built-in OPNsense test confirms that a user is authenticated and attached to his group (figure 14).

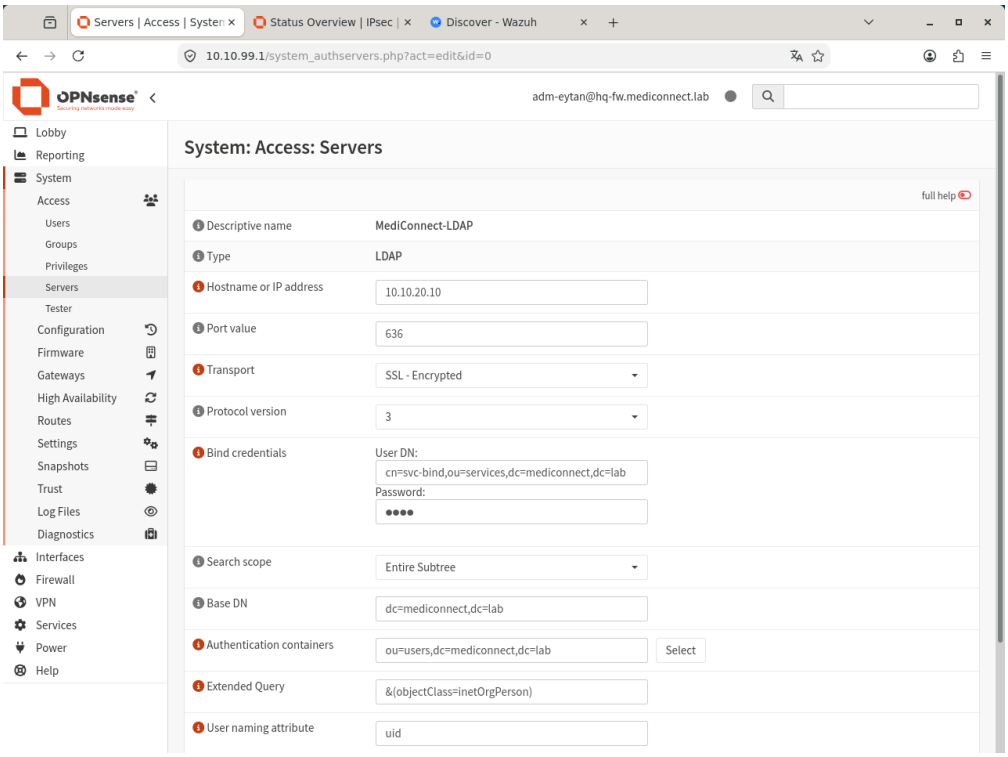


Figure 13. LDAP server configuration on OPNsense (LDAPS, port 636)

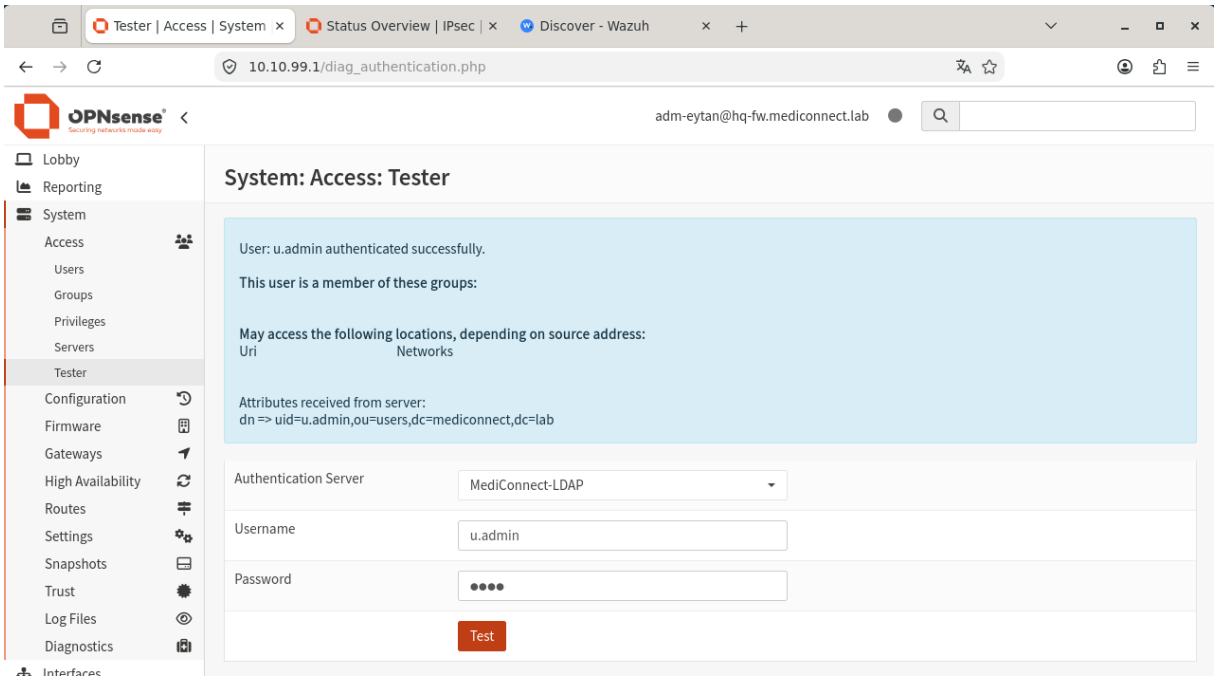


Figure 14. Successful LDAP authentication test for u.admin

Table 6 sums up the mechanisms per population. Doctors benefit from a real MFA: the possession of the certificate and the knowledge of the password. This point is shown in detail in the DMZ section.

Population	Mechanism	Factors
Patients	Application access over HTTPS	1
Doctors	Mandatory client certificate and password	2
Remote work and sales	OpenVPN: client certificate and LDAP credentials	2
Administrators	VPN of the admins group then SSH by keys	key and password
Site to site	IPsec IKEv2 with a strong pre-shared key	

Table 6. Authentication mechanisms per population

7 Filtering policy and identity-based rules

The filtering policy is the core of the project. It turns the trust levels into concrete rules. Table 7 gives the main matrix between zones. It is read from the source (row) toward the destination (column).

Source \ Dest.	INTERNET	DMZ	DEMO	LAN	SERV.	MGMT
INTERNET		443	×	×	×	×
DMZ	upd.		×	×	×	logs
DEMO	×	×		×	×	logs
LAN	80/443/53	×	×		id.	×
SERVERS	upd.	×	×	×		logs
MGMT	upd.	22	22	×	22	
BR-LAN	via BR	×	×	×	id.	×

Table 7. Filtering matrix between zones (× : denied and logged ; upd. : updates ; logs : 1514/1515 to the SIEM ; id. : see identity-based rules)

The identity-based rules detail who reaches what, for the remote users, the HQ LAN and the branch site (table 8). Each line follows from a recognized source address, obtained thanks to the fixed VPN addresses or to the subnet of the site.

Source	Allowed	Denied
grp-support	Support application (.22)	everything else
grp-compta	Accounting server (.23)	everything else
grp-employes	Office resources (.24)	everything else
grp-it	Technical (.25 on 22 and 443), SSH to servers	firewalls, management
grp-admins	Full management zone (GUI, SIEM, SSH)	
grp-commerciaux	CRM (.21) and demo zone (.40.10)	production, management
HQ LAN	Office, support, CRM, DNS	management, DMZ, demo, LDAP, accounting, technical
Branch LAN	Office, support, CRM, DNS	management, DMZ, demo, LDAP

Table 8. Identity-based filtering rules

These rules rely on OPNsense aliases (figure 15) that group the addresses and the ports, which keeps the configuration readable.

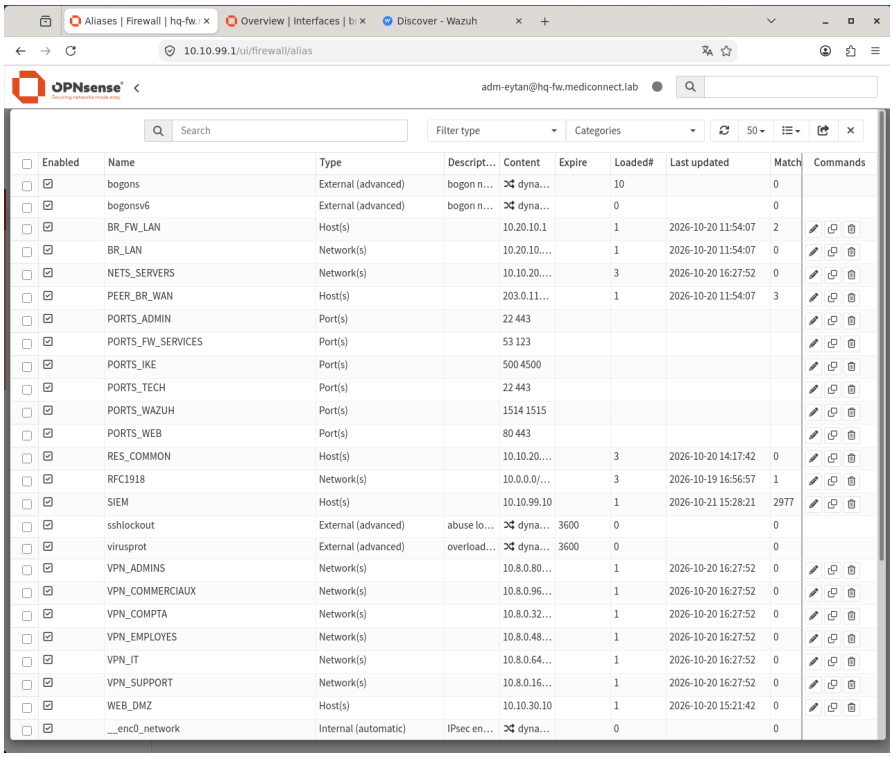


Figure 15. OPNsense aliases: VPN groups, ports and hosts

The rules applied per VPN group are visible on the OpenVPN interface of the firewall (figure 16). One finds there, line by line, the match between a group and its resource. The rules of an internal zone, for example the HQ LAN, follow the same principle (figure 17).

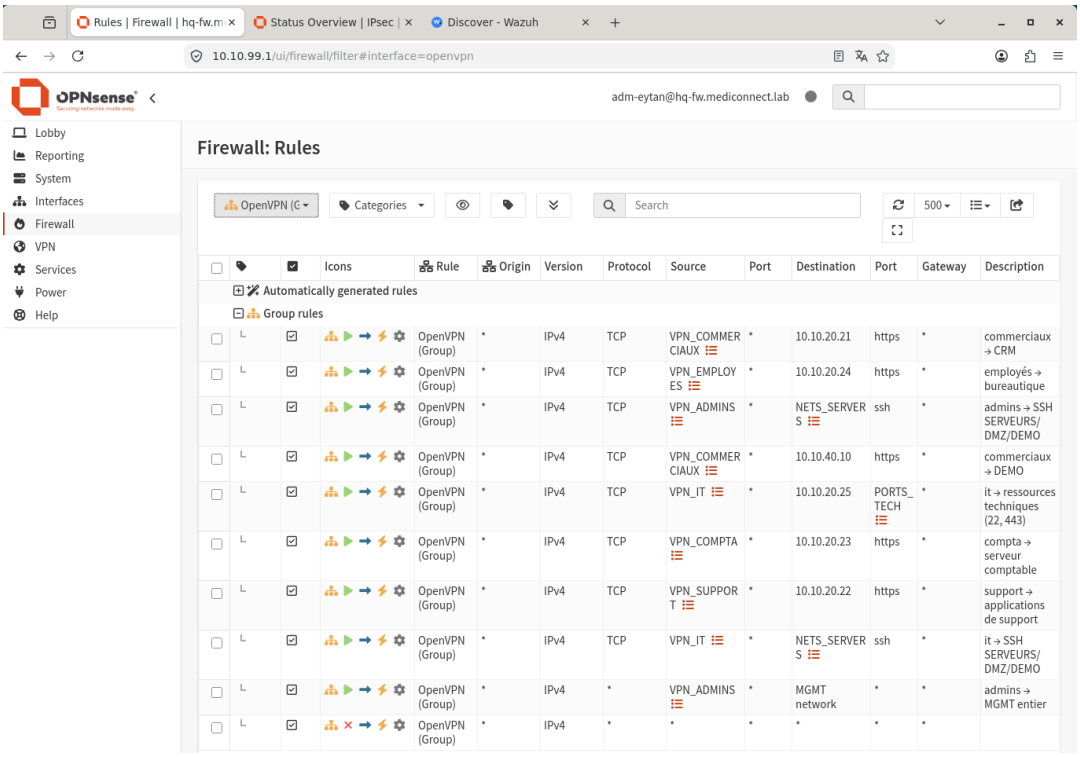


Figure 16. Filtering rules per group on the OpenVPN interface

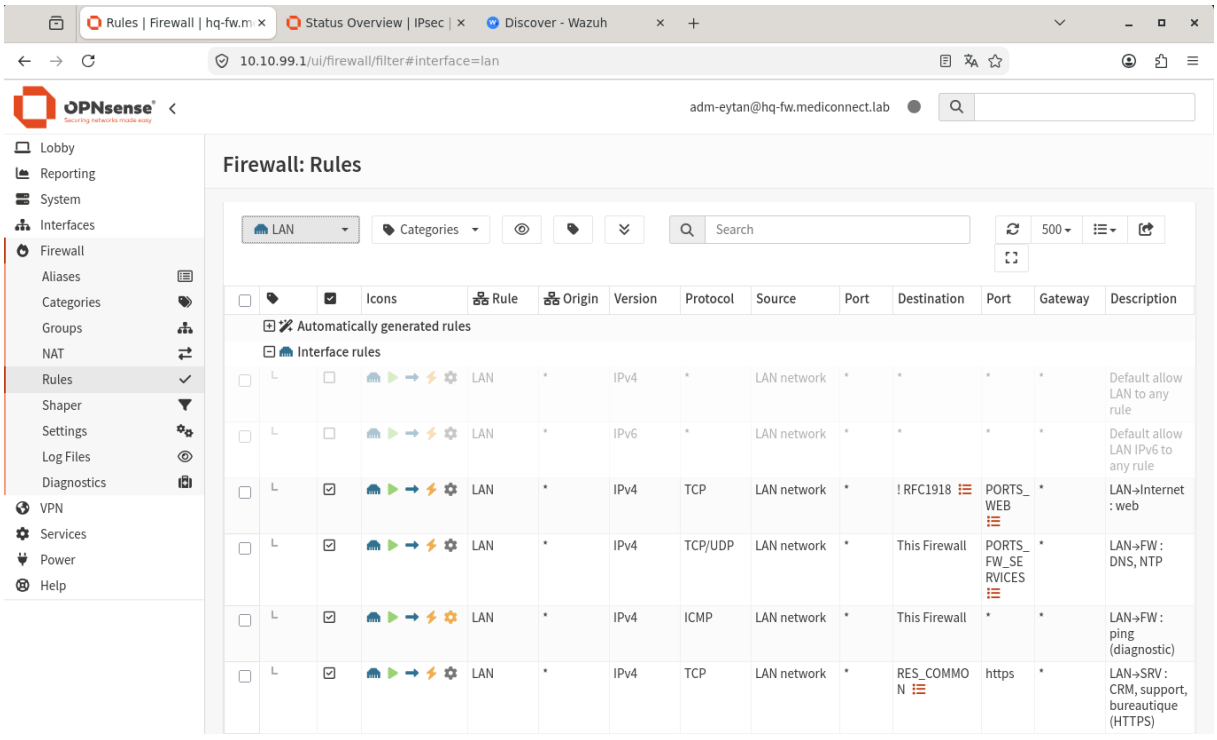


Figure 17. LAN interface rules: web egress, targeted resources, no administration

8 Application control

The application control relies on Suricata in IPS mode, placed on HQ-FW. Two rulesets are used: a subset of ET Open for attacks and scans, and the OPNsense-App-detect ruleset to recognize and block applications such as social media or streaming on the LAN-to-Internet traffic.

Figure 18 shows the Suricata configuration (IPS mode with Netmap, monitored interfaces). A policy (figure 19) turns the default action from *alert* to *drop* for the chosen categories, which moves the system from plain detection to actual blocking.

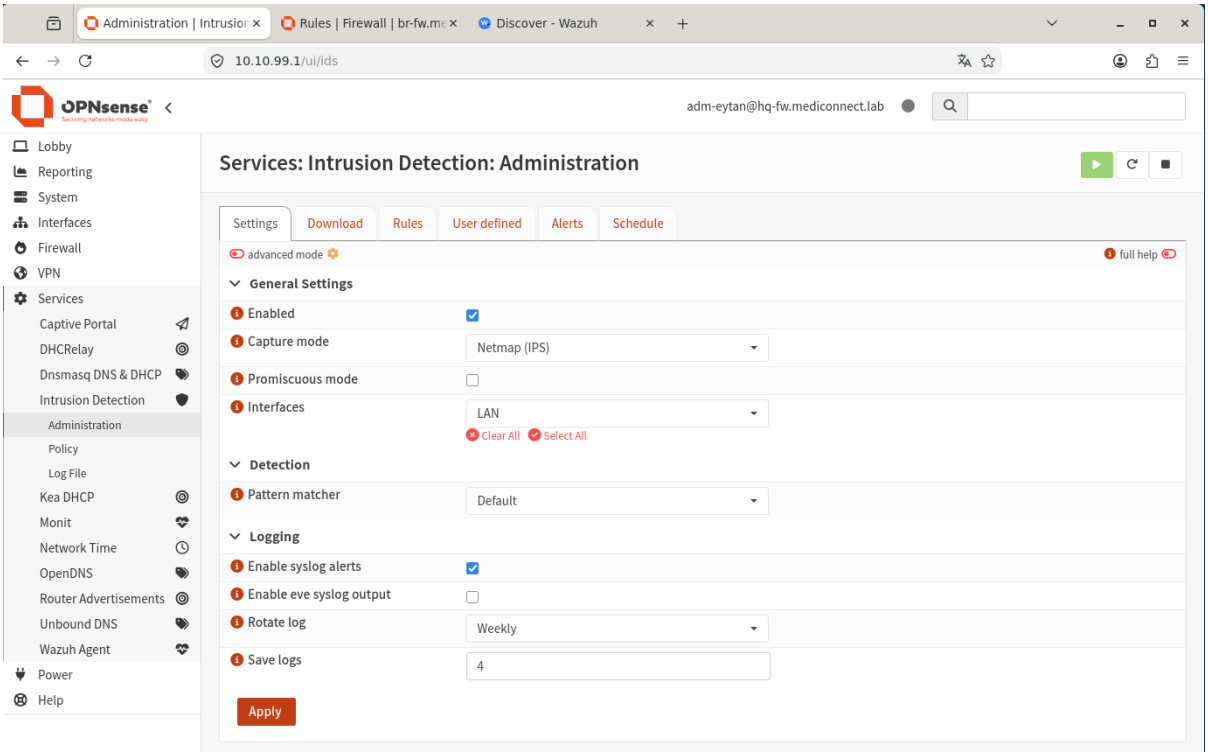


Figure 18. Suricata in IPS mode (Netmap), logging enabled

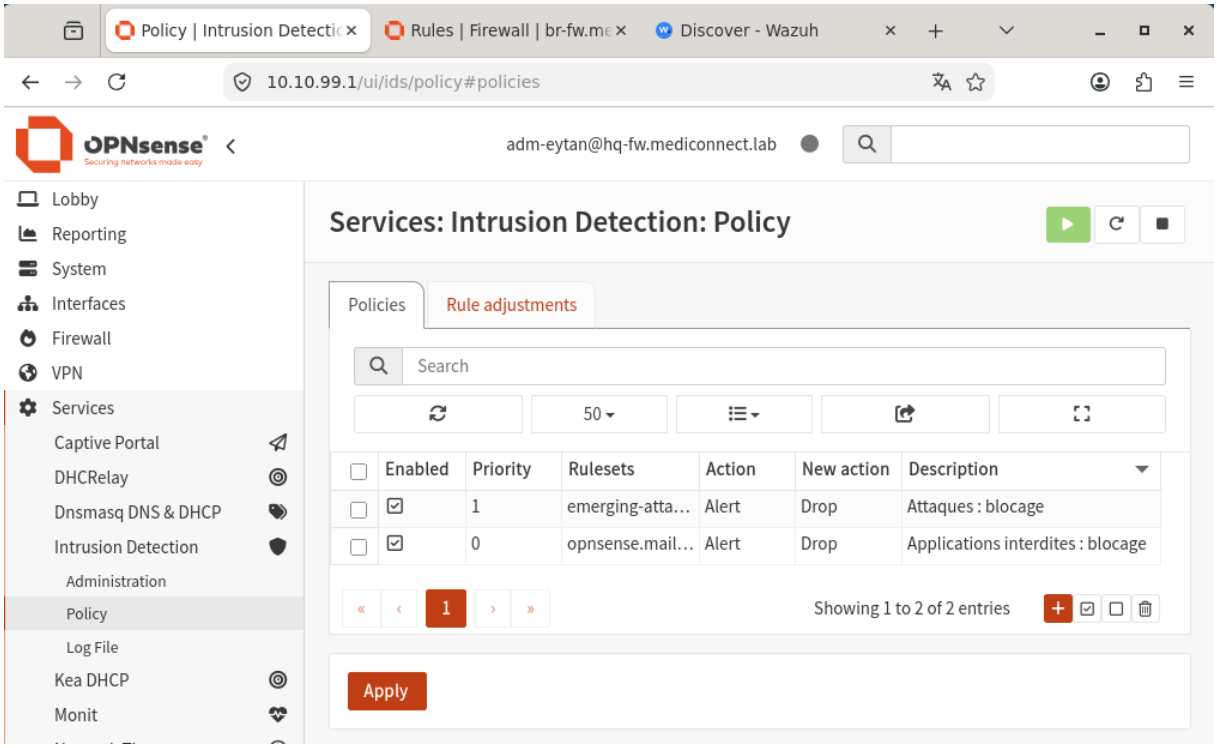


Figure 19. Suricata policies: blocking of attacks and disallowed applications

The demonstration is concrete: from the LAN workstation, a request toward a social network is blocked and the event appears in the alerts (figure 20). Indeed the OPNsense-App-detect

signature recognizes the request and the *drop* action of the policy stops it.

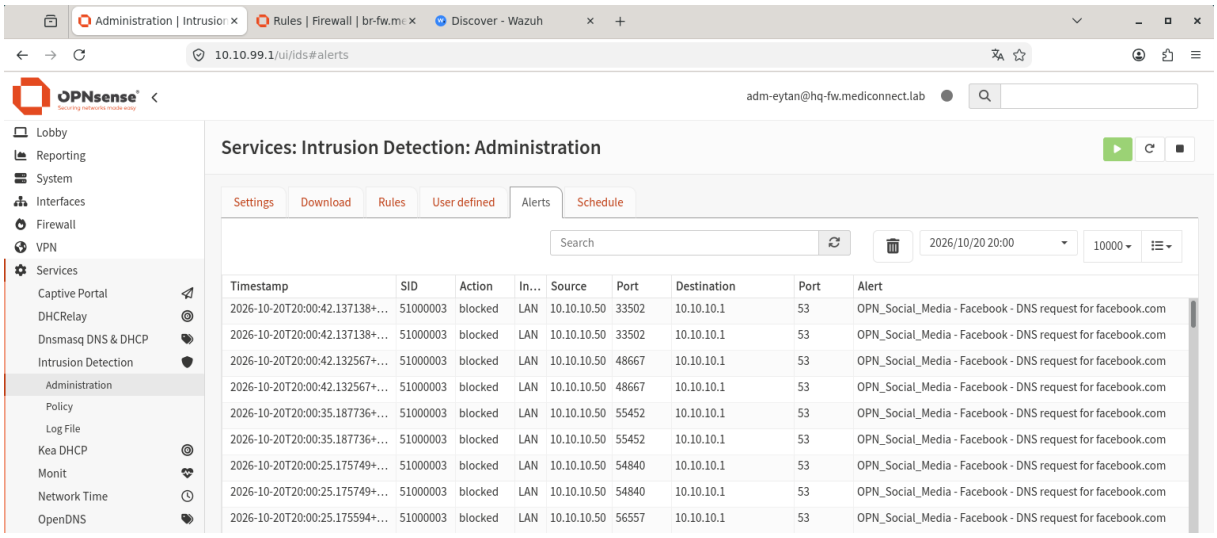


Figure 20. Suricata alert: request toward a social network blocked

To this network control, an nginx reverse proxy is added in front of the portal, which filters the HTTP methods, limits the rate and adds security headers. This point is detailed with the DMZ.

9 DMZ protection and portal exposure

The portal is exposed by an address redirection (DNAT): port 443 of the public address is redirected toward DMZ-WEB, and port 80 only to send back to HTTPS (figure 21). No content is served in clear text: nginx answers on port 80 with a 301 redirection and nothing else.

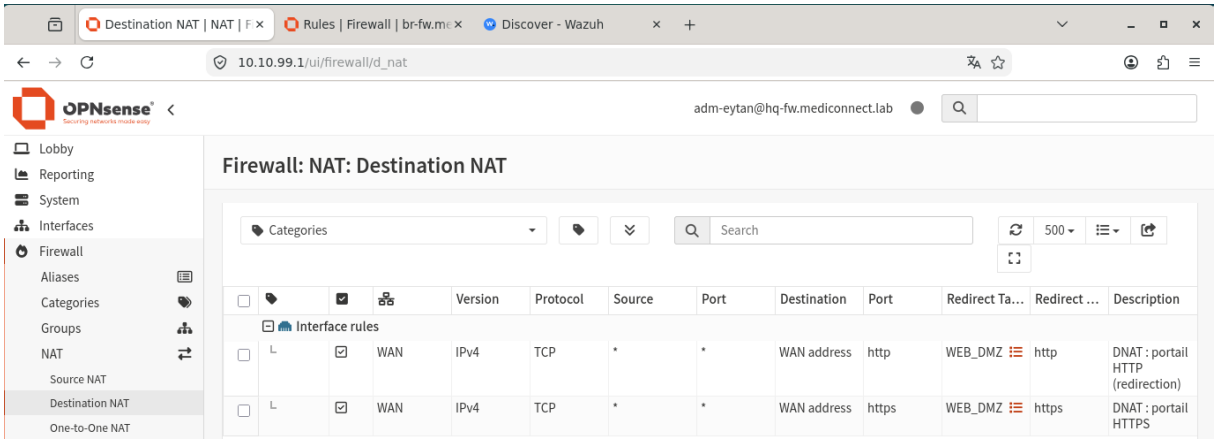


Figure 21. DNAT redirection: 443 and 80 toward DMZ-WEB

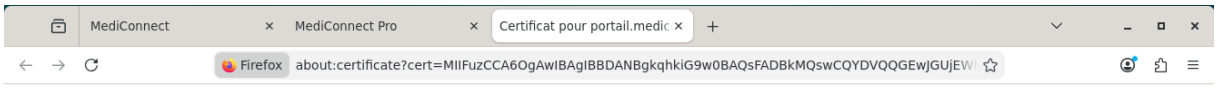
The nginx server tells apart two sites. The public portal is reachable by patients (figure 22), with a server certificate signed by the internal authority (figure 23). It accepts only TLS 1.2 and 1.3, adds the HSTS and X-Frame-Options headers, limits the rate and refuses any method other than GET and HEAD.



MediConnect

Prenez rendez-vous avec un professionnel de santé. (POC : page fictive)

Figure 22. Public portal reachable by patients



Certificat

portail.mediconnect.lab | MediConnect-CA

Nom du sujet

Pays	FR
État / Province	Ile-de-France
Localité	Paris
Organisation	MediConnect
Nom courant	portail.mediconnect.lab

Nom de l'émetteur

Pays	FR
État / Province	Ile-de-France
Localité	Paris
Organisation	MediConnect
Nom courant	MediConnect-CA

Figure 23. Portal certificate signed by the internal authority

The professional area `pro.mediconnect.lab` applies the doctor MFA. The browser asks first for a client certificate (figure 24), then for a password (figure 25). The area is shown only once both factors are validated (figure 26). A verification page confirms the identity carried by the certificate (figure 27).

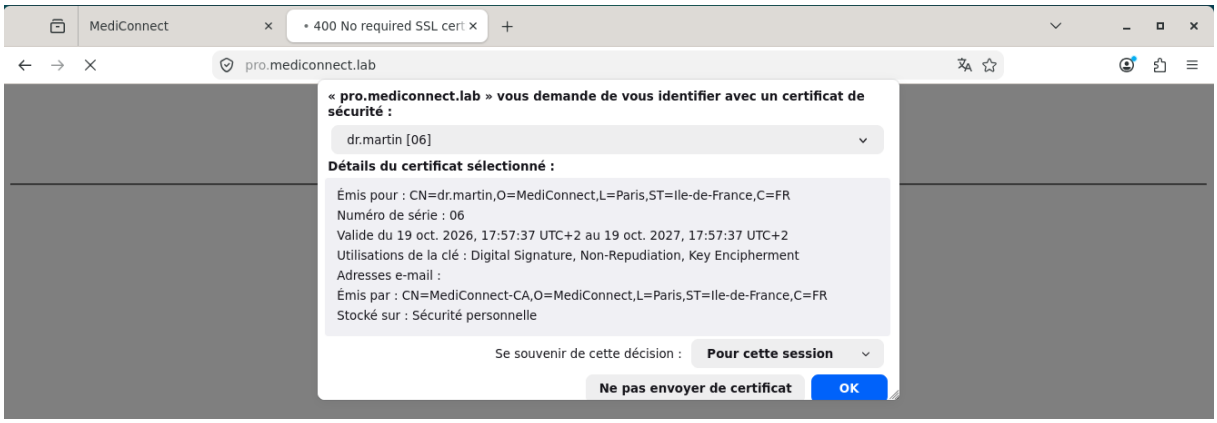


Figure 24. Doctor area: client certificate request

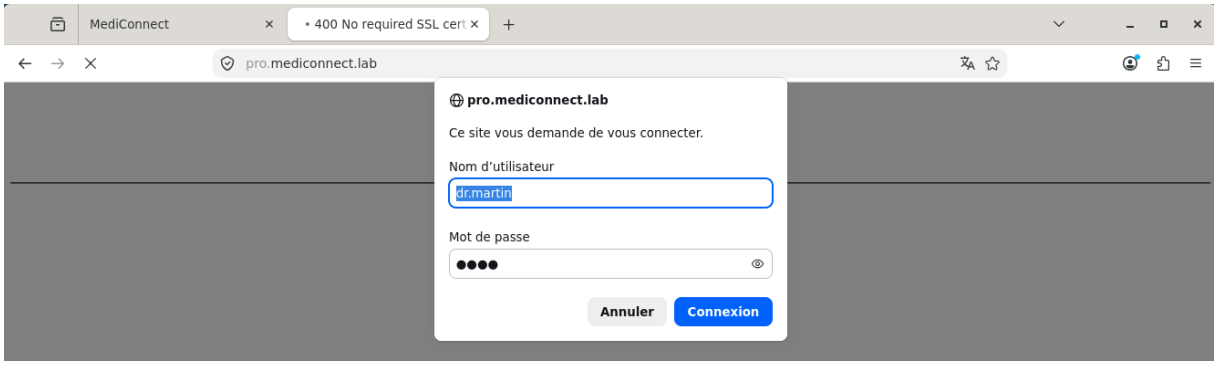


Figure 25. Doctor area: password request

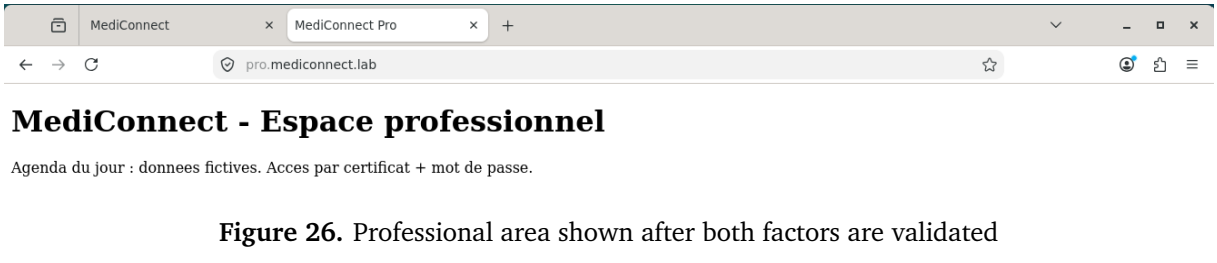


Figure 26. Professional area shown after both factors are validated

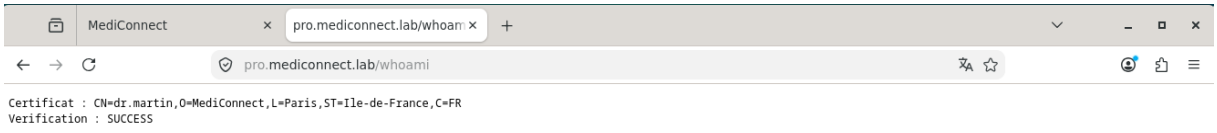


Figure 27. Certificate verification: identity dr.martin, result SUCCESS

The important point is that doctors have no access to the internal network: they only reach port 443 of the DMZ. The DMZ itself can never initiate a connection toward the LAN, the servers or the management, with the sole exception of its logs toward the SIEM. The DMZ-WEB host is also hardened: local nftables firewall in default deny, SSH by keys from the management only, and a Wazuh agent.

10 Secure administration

The administration is deliberately separated from the user traffic. The OPNsense GUI only listens on the management interface (figure 28), the direct root login is forbidden and the password

authentication is disabled in favor of keys. The administration accounts are named and distinct from the user accounts (figure 29).

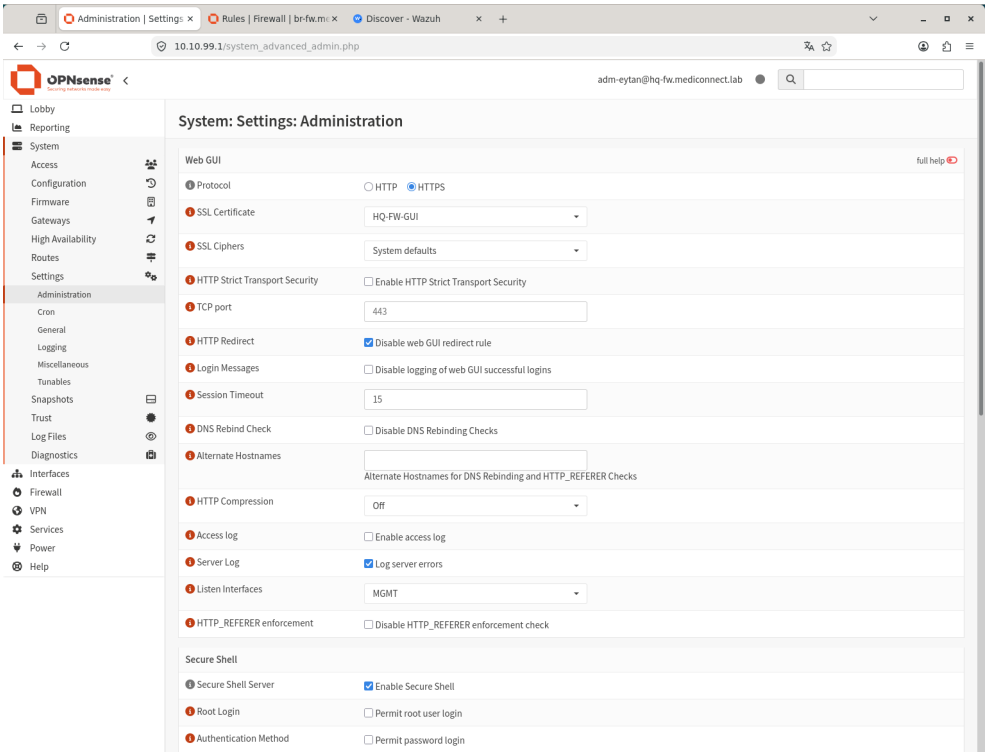


Figure 28. OPNsense administration: HTTPS, listening on MGMT, SSH by keys

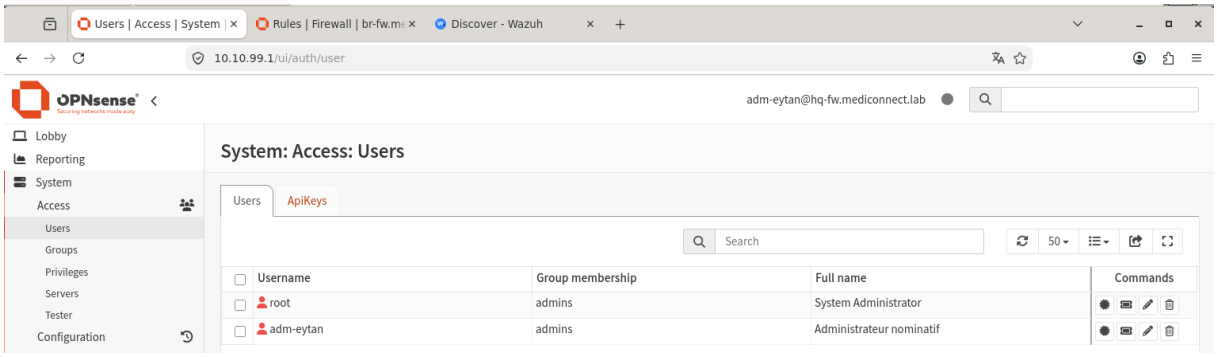


Figure 29. Named accounts separated from the user accounts

For an SSH connection to succeed, two barriers have to allow it: the central firewall, which only accepts the administration flow from the management zone, then the local firewall of the host. The SSH server finally enforces the key and restricts the allowed accounts. This is a defense in depth: one mistake on a single barrier is not enough to open the access.

The key test of this separation is simple: a LAN workstation can neither reach the firewall GUI, nor open an SSH session toward the servers. It is shown in the tests section. Remote administrators go through the VPN of the admins group, then reach the management zone. The administration of the branch firewall is done through the IPsec tunnel.

11 Logging and monitoring

The monitoring is centralized on Wazuh. Each machine sends its logs to the SIEM through an agent, on port 1514, with an authenticated and encrypted channel. Port 1515 only serves the initial enrollment of the agent. These flows are allowed precisely by the firewall, only toward the SIEM address, in line with the matrix.

Source	Collected content
HQ-FW and BR-FW	Blocked packets (filterlog), Suricata alerts, VPN failures, authentications
DMZ-WEB, DEMO-WEB	nginx logs, file integrity (FIM) of /var/www and /etc/nginx
SRV-LDAP, SRV-APPS, ADMIN-WS	SSH authentications, file integrity

Table 9. Log sources and content

The six agents are active and report well to the SIEM (figure 30). The configuration of the firewall agent (figure 31) shows the monitored applications, among them the firewall and the intrusion detection.

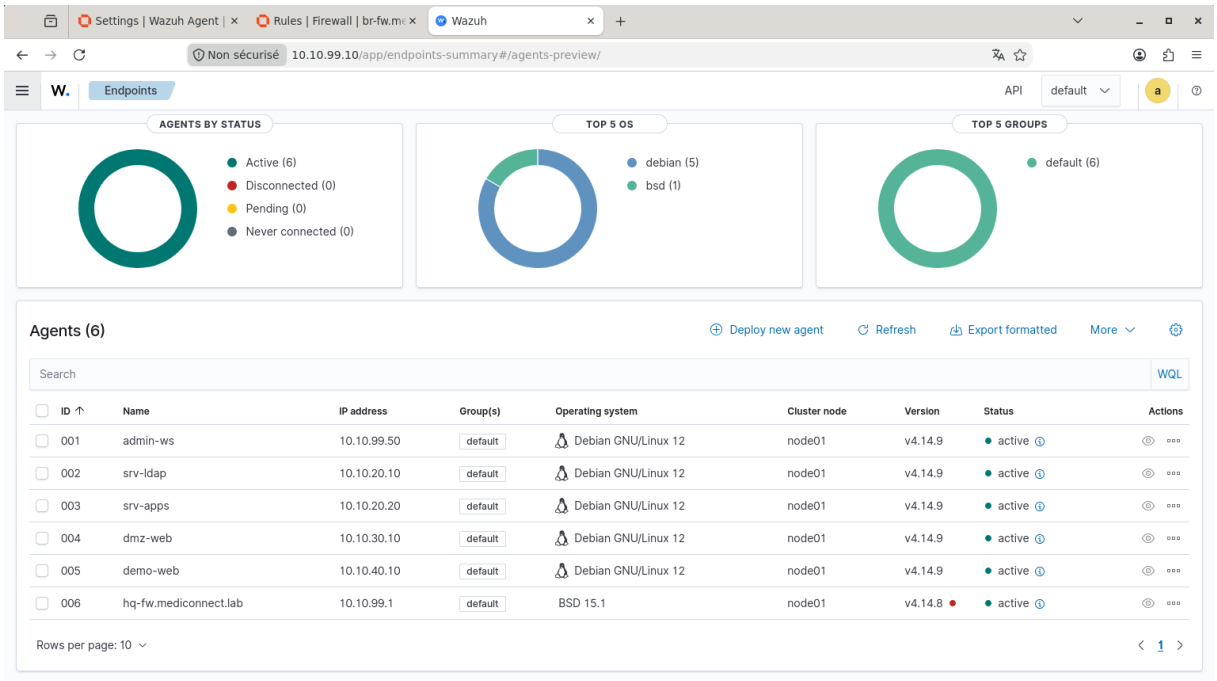


Figure 30. The six Wazuh agents active

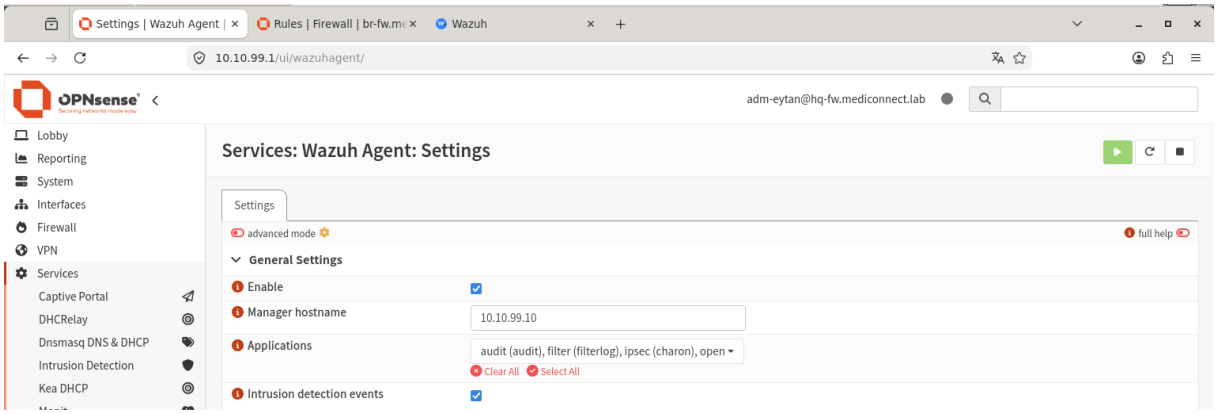


Figure 31. Wazuh agent on OPNsense: monitored applications

Three kinds of security events are put forward by custom rules. First the VPN authentication failures, with a rule that triggers a brute-force alert from three failures in 120 seconds (figure 32). Then the SSH attempts with a denied account, caught on the server side (figure 33). Finally the file integrity monitoring, which flags any file added in the web tree (figure 34).

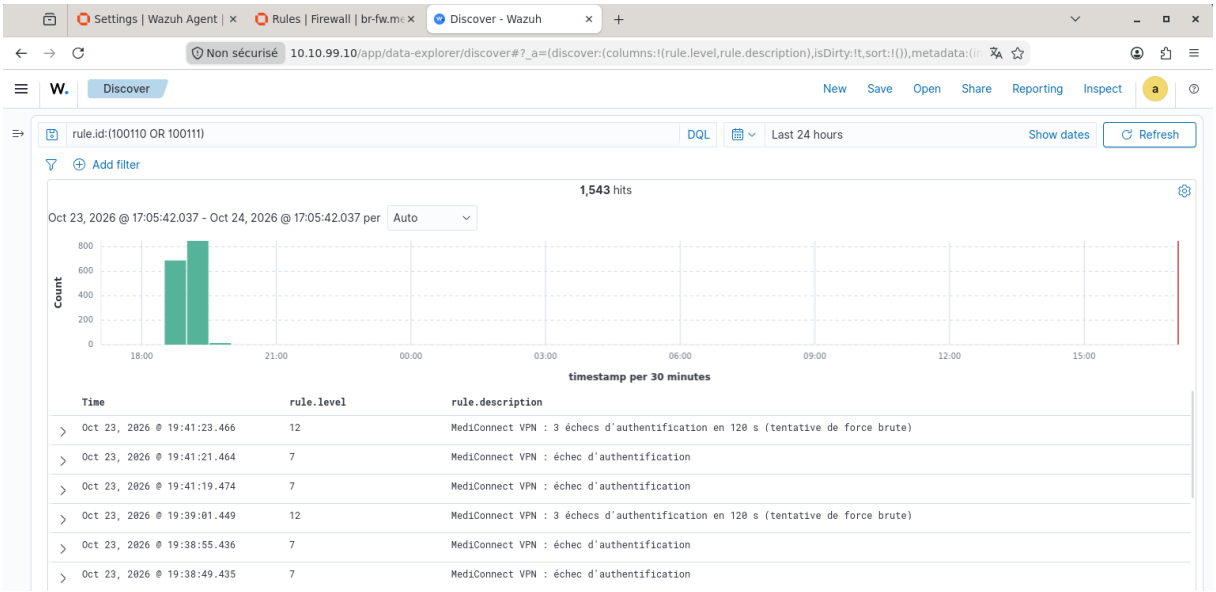


Figure 32. Wazuh alerts: VPN authentication failures and brute-force alert

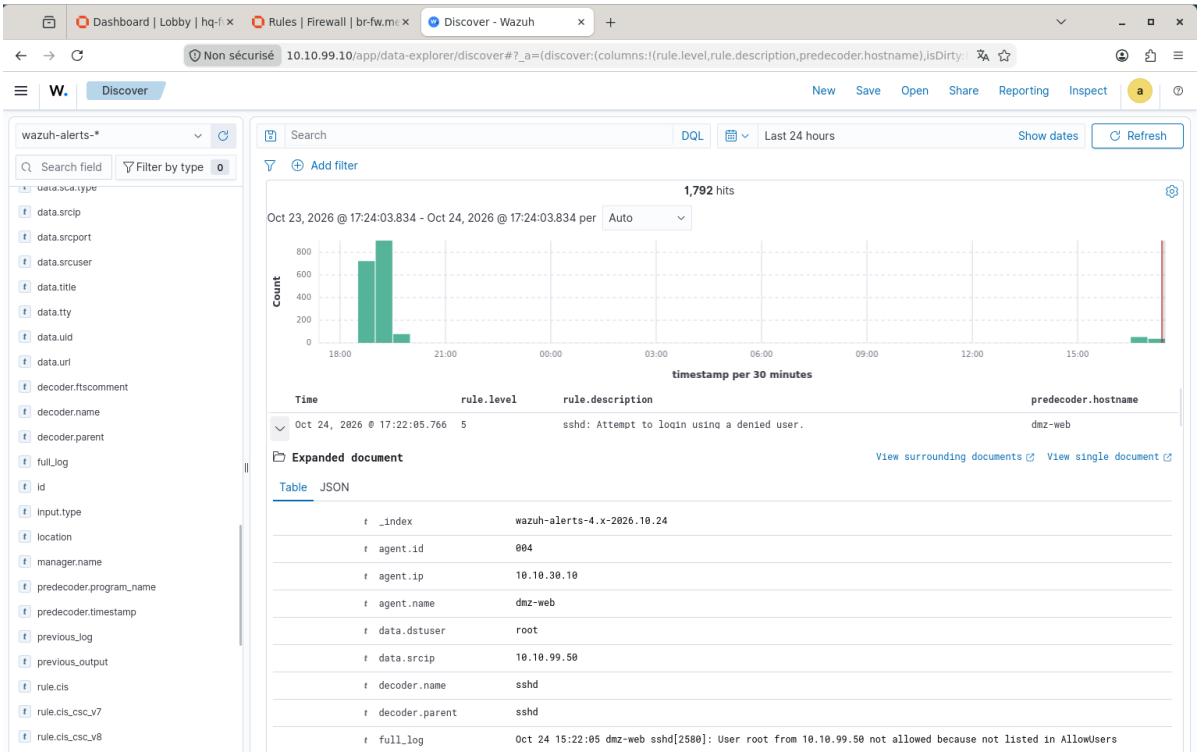


Figure 33. Wazuh alert: SSH attempt with a denied account

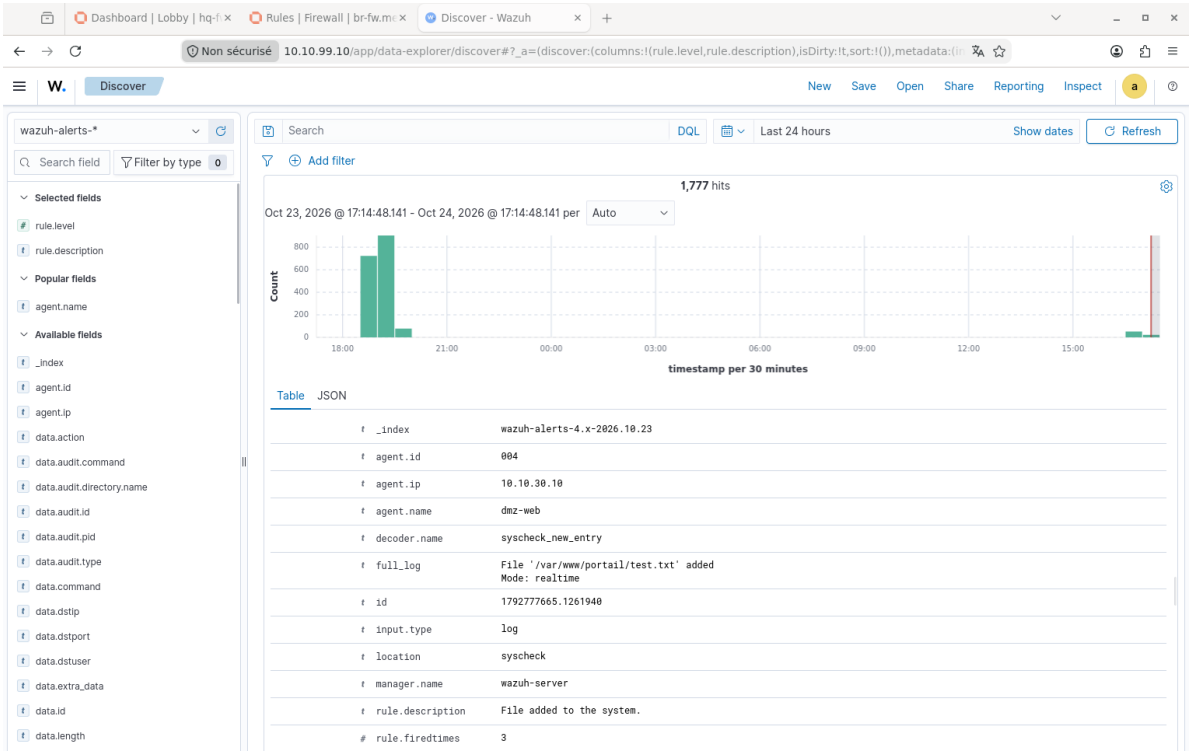


Figure 34. File integrity monitoring: an added file detected

The correlation is possible because the clock of every machine is synchronized by NTP. Without it, it would be impossible to link an event seen on the firewall to its equivalent in Wazuh.

12 Test campaign

The solution was validated by a test campaign that covers each requirement. To make it reproducible, two scripts were written: `tcheck.sh`, which checks from a workstation a list of expected accesses (some have to succeed, others have to be refused), and `vpn-test.sh`, which brings up the six tunnels in turn and checks the rights of each group. These test scripts were written with the help of an AI, then reviewed and run in the lab. Their code is in appendix B.5.

Table 10 sums up the tests and their result.

12.1 Patients, doctors and exposure (T01 to T05)

The exposure tests are run from the Internet host. The portal answers over HTTPS, the cleartext version is redirected, the security headers are present, the pro area without a certificate is refused and the dangerous methods are rejected. The rate limiting returns 429 responses under load.

```
$ curl -sI http://portail.mediconnect.lab | head -1
HTTP/1.1 301 Moved Permanently

$ curl -sI https://portail.mediconnect.lab | grep -iE "strict|x-frame"
Strict-Transport-Security: max-age=31536000
X-Frame-Options: DENY

$ curl -s -o /dev/null -w "%{http_code}\n" https://pro.mediconnect.lab/
400
```

ID	Test	Result
T01	Patient: portal over HTTPS	Page shown
T02	Patient: access over HTTP (port 80)	Redirected with 301
T03	Access to the pro area without a certificate	Refused (400)
T04	Doctor: certificate and password	Access granted
T05	Internet toward the internal servers	Refused
T06	DMZ toward the LAN or the servers	Refused and logged
T07	Site 2 toward allowed resources ; MGMT toward BR-FW	Access granted
T08	Site 2 toward MGMT, DMZ, DEMO	Refused
T09 to T14	VPN per group: access to the profile, refusal of the rest	Compliant
T15	VPN without a certificate or with a wrong password	Refused and alert
T16	LAN toward the firewall GUI or SSH to servers	Refused
T17	Demonstration toward production	Refused
T18	LAN toward a blocked application	Refused and alert
T19	Scan from the Internet toward the WAN	Filtered ports
T20	Correlation: one action, a firewall log and a Wazuh log	Verified

Table 10. Test plan and results

```
$ curl -s -o /dev/null -w "%{http_code}\n" -X DELETE https://portail.mediconnect.lab/
405

$ seq 100 | xargs -P20 -I{} curl -s -o /dev/null -w "%{http_code}\n" \
    https://portail.mediconnect.lab/ | sort | uniq -c
     62 200
     38 429
```

A port scan from the Internet only reveals 80 and 443, everything else is filtered. The UDP ports of the VPN and of IPsec do not appear open, since they only answer to legitimate clients.

```
$ sudo nmap -Pn -sS -p 1-1024 203.0.113.10
PORT    STATE SERVICE
80/tcp  open  http
443/tcp open  https
Not shown: 1022 filtered tcp ports (no-response)
```

12.2 Interconnection and isolation of site 2 (T07, T08)

From the branch workstation, the allowed accesses work (CRM, support, office) and everything else is refused. The script output confirms the full compliance.

```
== tcheck brpc -- br-pc
OK  expected=1 got=1  T07 BR -> CRM (10.10.20.21:443)
OK  expected=1 got=1  T07 BR -> Support (10.10.20.22:443)
OK  expected=1 got=1  T07 BR -> Office (10.10.20.24:443)
OK  expected=0 got=0  T08 BR -> LDAPS (10.10.20.10:636)
OK  expected=0 got=0  T08 BR -> DMZ (10.10.30.10:443)
OK  expected=0 got=0  T08 BR -> SIEM (MGMT) (10.10.99.10:443)
=== COMPLIANT ===
```

12.3 Identity-based remote access (T09 to T14)

This test is the most representative of the identity policy. The `vpn-test.sh` script brings up each tunnel and checks, for the twelve targets, that only the accesses of the profile succeed.

```
[u.support] tunnel up, 10.8.0.17 (IP ok)
OK    crm       10.10.20.21:443  expected=0 got=0
OK    support   10.10.20.22:443  expected=1 got=1
OK    compta    10.10.20.23:443  expected=0 got=0
OK    bureau    10.10.20.24:443  expected=0 got=0
OK    tech443   10.10.20.25:443  expected=0 got=0
OK    tech22    10.10.20.25:22   expected=0 got=0
OK    demo      10.10.40.10:443  expected=0 got=0
OK    dmz443    10.10.30.10:443  expected=0 got=0
OK    ldap636   10.10.20.10:636  expected=0 got=0
OK    ssh-srv   10.10.20.10:22   expected=0 got=0
OK    ssh-dmz   10.10.30.10:22   expected=0 got=0
OK    mgmt-gui  10.10.99.1:443   expected=0 got=0
[u.compta] tunnel up, 10.8.0.33 (IP ok)
OK    compta    10.10.20.23:443  expected=1 got=1
...  (every other target expected=0 got=0)
[u.employe] tunnel up, 10.8.0.49 (IP ok)
OK    bureau    10.10.20.24:443  expected=1 got=1
...  (the rest expected=0 got=0)
[u.it] tunnel up, 10.8.0.65 (IP ok)
OK    tech443   10.10.20.25:443  expected=1 got=1
OK    tech22    10.10.20.25:22   expected=1 got=1
OK    ssh-srv   10.10.20.10:22   expected=1 got=1
OK    ssh-dmz   10.10.30.10:22   expected=1 got=1
...  (the rest expected=0 got=0)
[u.admin] tunnel up, 10.8.0.81 (IP ok)
OK    ssh-srv   10.10.20.10:22   expected=1 got=1
OK    ssh-dmz   10.10.30.10:22   expected=1 got=1
OK    mgmt-gui  10.10.99.1:443   expected=1 got=1
...  (the rest expected=0 got=0)
[u.commercial] tunnel up, 10.8.0.97 (IP ok)
OK    crm       10.10.20.21:443  expected=1 got=1
OK    demo      10.10.40.10:443  expected=1 got=1
...  (the rest expected=0 got=0)
=== ALL COMPLIANT ===
```

12.4 Administration separation (T16)

From the LAN workstation, the check confirms that the access to the allowed business resources works and that any administration attempt (firewall GUI, SSH to the servers, access to the management zone) is refused.

```
== tcheck hqpc -- hq-pc
OK  expected=1 got=1  LAN -> CRM (10.10.20.21:443)
OK  expected=1 got=1  LAN -> Office (10.10.20.24:443)
OK  expected=0 got=0  T16 LAN -> SSH SRV-LDAP (10.10.20.10:22)
OK  expected=0 got=0  T16 LAN -> firewall GUI (LAN) (10.10.10.1:443)
OK  expected=0 got=0  T16 LAN -> firewall GUI (MGMT) (10.10.99.1:443)
OK  expected=0 got=0  LAN -> DMZ (10.10.30.10:443)
=== COMPLIANT ===
```

The direct attempt from the LAN ends with a network refusal, the workstation simply has no allowed route toward the servers.

```
$ ssh -o ConnectTimeout=5 adm-eytan@10.10.20.10
ssh: connect to host 10.10.20.10 port 22: No route to host
```

The other way around, from the administration workstation, the key-based access works and it is well logged on the server side.

```
$ ssh adm-eytan@10.10.20.10 'sudo grep "Accepted publickey" /var/log/auth.log | tail -1'
srv-ldap sshd: Accepted publickey for adm-eytan from 10.10.99.50 port 47600 ssh2: ED25519
```

12.5 Demonstration and refused flows (T06, T17)

The refusal of the flows that should not exist is visible live in the firewall logs. Figure 35 shows, on the DMZ interface, the blocking of every attempt from DMZ-WEB toward the internal servers. The same observation on the WAN interface (figure 36) and on the LAN confirms that the default deny rule works and logs.

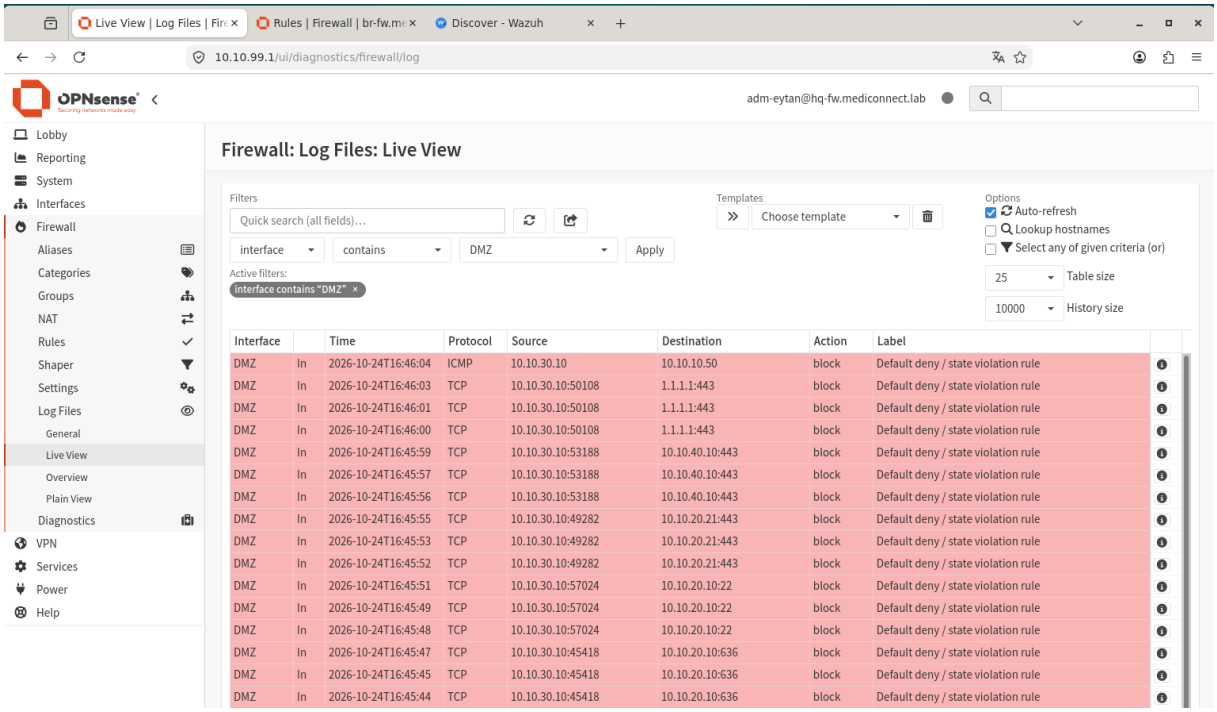


Figure 35. Live log: the DMZ cannot reach the inside (blocks)

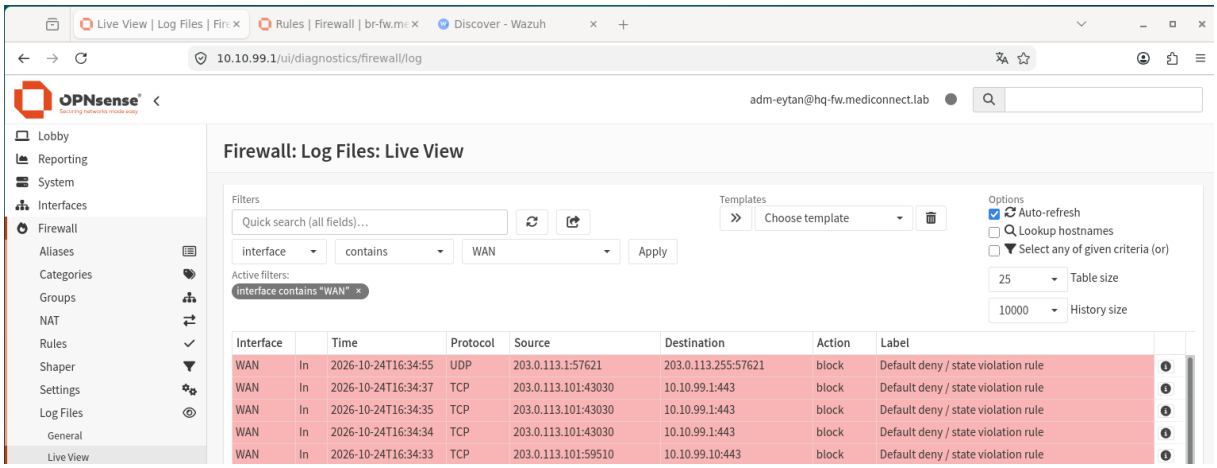


Figure 36. Live log on the WAN: inbound attempts blocked

12.6 Attack detection and correlation (T15, T18, T19, T20)

A VPN connection attempt with a wrong password is refused on the client side, and three close attempts trigger the brute-force alert in Wazuh (see figure 32).

```
$ for i in 1 2 3; do sudo timeout 20 openvpn --config ~/u.support.ovpn \
    --auth-user-pass /tmp/bad.txt 2>&1 | grep -m1 AUTH_FAILED; done
AUTH: Received control message: AUTH_FAILED
AUTH: Received control message: AUTH_FAILED
AUTH: Received control message: AUTH_FAILED
```

The correlation of one same action between the firewall log and Wazuh is thus shown: the VPN failure, the application block and the added monitored file all appear in the SIEM, each attached to its rule.

13 Limitations

The solution satisfies the requirements, however it stays a proof of concept. The limitations are therefore the following.

- No high availability: a single firewall per site and a single host. A hardware failure stops everything.
- No VLAN: the segment isolation fits the lab but does not represent a real physical network, where one would use VLANs.
- The Internet is simulated and the certificates come from an internal authority, not from a public one.
- The applications are simulated by static pages: there is no real application-layer testing, for example a full web application firewall against SQL injection.
- On the LAN and the branch site, the identity relies on the subnet and not on the user. A captive portal would be the natural evolution.
- The doctor MFA combines a certificate and a password, but nginx does not check the link between the two: they are two independent controls. A TOTP was not deployed.
- IPsec relies on a pre-shared key: there is no per-peer revocation, which certificates would bring.
- The fixed VPN addresses are maintained by hand, one per user. An automation would be desirable at a larger scale.

14 Conclusion

The platform infrastructure answers all the requirements. The two sites are linked by an encrypted tunnel, the remote accesses are limited to the profile of each user, the patients and the doctors reach the portal without ever touching the internal network, production is separated from demonstration, the application control is active, the administration is isolated from the user traffic, and the security events are centralized and correlated in a SIEM.

The approach relied on a constant principle: the simplest solution that really satisfies each need. Indeed, in a security environment, simplicity is itself a quality, because a configuration that one fully understands is a configuration that one knows how to check and to fix. The

identified limitations do not question these results, they draw the road toward a production version. Personally, this project showed me that the security of a network does not come from a single tool, but from the consistency of the whole, from the addressing plan up to the logging.

A Virtual machines inventory

Machine	System	Address	Role
HQ-FW	OPNsense	.10 WAN, .1 per zone	Central firewall, IPsec, OpenVPN, Suricata, CA
BR-FW	OPNsense	.20 WAN, 10.20.10.1	Branch firewall, IPsec
SRV-LDAP	Debian 12	10.10.20.10	OpenLDAP directory
SRV-APPS	Debian 12	10.10.20.20 (.21 to .25)	Simulated business resources
DMZ-WEB	Debian 12	10.10.30.10	nginx: portal and pro area
DEMO-WEB	Debian 12	10.10.40.10	Demo copy
SIEM-WAZUH	appliance	10.10.99.10	Collection and alerts
ADMIN-WS	Debian XFCE	10.10.99.50	Administration workstation
HQ-PC	Debian XFCE	10.10.10.50	LAN user
BR-PC	Debian XFCE	10.20.10.50	Branch user
EXT-PATIENT	Debian XFCE	203.0.113.101	Patient and doctor
EXT-VPN	Debian XFCE	203.0.113.102	VPN client and tests

Table 11. Inventory of the twelve virtual machines

B Key configurations

B.1 nginx: public portal and doctor area

```
server_tokens off;
limit_req_zone $binary_remote_addr zone=perip:10m rate=10r/s;
limit_req_status 429;
ssl_ciphers ECDHE-RSA-AES128-GCM-SHA256:ECDHE-RSA-AES256-GCM-SHA384;

# port 80: redirection to HTTPS only
server { listen 80; server_name portail.mediconnect.lab;
         return 301 https://portail.mediconnect.lab$request_uri; }

# public portal (patients)
server {
    listen 443 ssl; server_name portail.mediconnect.lab;
    root /var/www/portail;
    add_header Strict-Transport-Security "max-age=31536000" always;
    add_header X-Frame-Options "DENY" always;
    add_header X-Content-Type-Options "nosniff" always;
    limit_req zone=perip burst=20 nodelay;
    if ($request_method !~ ^(GET|HEAD)$) { return 405; }
}

# doctor area: client certificate + password
server {
    listen 443 ssl; server_name pro.mediconnect.lab;
    root /var/www/pro;
    ssl_client_certificate /etc/nginx/tls/ca.crt;
    ssl_verify_client on;
    ssl_verify_depth 1;
    auth_basic "Professional area";
    auth_basic_user_file /etc/nginx/.htpasswd-pro;
    if ($request_method !~ ^(GET|HEAD)$) { return 405; }
    location = /whoami {
```

```
        default_type text/plain;
        return 200 "Certificate: $ssl_client_s_dn\nVerification: $ssl_client_verify\n";
    }
}
```

B.2 Local nftables firewall (servers and DMZ)

```
#!/usr/sbin/nft -f
flush ruleset
table inet filter {
  chain input {
    type filter hook input priority 0; policy drop;
    ct state established,related accept
    ct state invalid drop
    iif lo accept
    ip saddr 10.10.99.0/24 icmp type echo-request accept
    ip saddr { 10.10.99.0/24, 10.8.0.64/28, 10.8.0.80/28 } tcp dport 22 accept
    tcp dport 443 accept
  }
  chain forward { type filter hook forward priority 0; policy drop; }
  chain output  { type filter hook output priority 0; policy accept; }
}
```

B.3 SSH server hardening

```
# /etc/ssh/sshd_config.d/10-hardening.conf
PermitRootLogin no
PasswordAuthentication no
KbdInteractiveAuthentication no
PubkeyAuthentication yes
AuthenticationMethods publickey
AllowUsers adm-eytan
MaxAuthTries 3
LoginGraceTime 30
X11Forwarding no
AllowTcpForwarding no
ClientAliveInterval 300
LogLevel VERBOSE
```

B.4 Wazuh: decoder and custom rules

The decoder reads the OPNsense filterlog messages and extracts the useful fields. The rules flag a blocked packet, a scan (five blocks in 60 seconds), an out-of-profile access from the VPN, and the VPN authentication failures with brute-force detection.

```
<decoder name="opnsense-filterlog">
  <program_name>^filterlog</program_name>
</decoder>
<decoder name="opnsense-filterlog-v4">
  <parent>opnsense-filterlog</parent>
  <order>interface,action,direction,protocol,srcip,dstip,srcport,dstport</order>
</decoder>
```

```
<rule id="100100" level="3">
  <match>match,block,</match>
  <description>Firewall: packet blocked</description>
```

```
</rule>
<rule id="100101" level="10" frequency="5" timeframe="60">
  <if_matched_sid>100100</if_matched_sid>
  <same_srcip />
  <description>Firewall: 5+ blocks in 60 s (scan)</description>
  <mitre><id>T1046</id></mitre>
</rule>
<rule id="100102" level="9">
  <if_sid>100100</if_sid>
  <srcip>10.8.0.0/24</srcip>
  <description>VPN: out-of-profile access denied</description>
</rule>
<rule id="100110" level="7">
  <if_sid>81800</if_sid>
  <regex type="pcre2">SENT CONTROL \[(?!UNDEF)[^\]]+\]: 'AUTH_FAILED'</regex>
  <description>VPN: authentication failure</description>
</rule>
<rule id="100111" level="12" frequency="3" timeframe="120">
  <if_matched_sid>100110</if_matched_sid>
  <description>VPN: 3 failures in 120 s (brute force)</description>
  <mitre><id>T1110</id></mitre>
</rule>
```

B.5 Test scripts

As stated in the tests section, these two scripts were written with the help of an AI, then reviewed and run in the lab. The first one, `tcheck.sh`, tests a list of accesses from a workstation according to a profile (a 1 means the access has to succeed, a 0 that it has to be refused). The second one, `vpn-test.sh`, brings up each tunnel and checks the rights of its group.

```
# vpn-test.sh (excerpt): one expected tunnel IP per user,
# and the list of allowed accesses per group
declare -A EXP=(
 [u.support]="support"   [u.compta]="compta"   [u.employe]="bureau"
 [u.it]="tech443 tech22 ssh-srv ssh-dmz"
 [u.admin]="ssh-srv ssh-dmz mgmt-gui"
 [u.commercial]="crm demo" )

for u in u.support u.compta u.employe u.it u.admin u.commercial; do
  openvpn --config "./$u.ovpn" --auth-user-pass /tmp/auth.txt --daemon ...
  ip=$(ip -4 -o addr show tun0 | awk '{print $4}' | cut -d/ -f1)
  for t in "${TARGETS[@]}"; do
    # test each target, compare got with expected
    ...
  done
done
[ "$fail" = 0 ] && echo "=== ALL COMPLIANT ===" || echo "=== DEVIATIONS DETECTED ==="
```